SPIKA TECH™

MANUAL DE TERMINOLOGÍA DEL SGSI

HISTORIAL DEL DOCUMENTO			
Versión	**Resumen de modificaciones**	**Fecha de entrada**	**Sustituye a (Código, revisión)**
01	Primera versión del documento.	11/03/2025	N/A

REGISTRO DE FIRMAS			
Función:	**Elaborado por:**	**Revisado por:**	**Aprobado por:**
Departamento:	Responsable del SGSI	Dirección	Jefe de seguridad (o suplente)
Nombre:	David Pozo	Carlos Rodrigo	Carlos Zúñiga
Firma:	Firmado por POZO SANCHEZ DAVID - ***6992** el día 11/03/2025	Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN)	Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 11/03/2025 con un
Fecha:	11/03/2025	11/03/2025	11/03/2025

CONTENIDO

1 OBJETIVO 4
2 ALCANCE 4
3 NORMATIVA APLICABLE 4
4 TERMINOLOGÍA 5
5 REFERENCIAS 78

1 OBJETIVO

Esta guía se aplica en todos los sistemas de información de SPIKA TECH que dan soporte a los servicios especificados que se incluyen en cada ámbito de actuación de los Sistemas de Gestión de Seguridad de la Información y Continuidad de Negocio implantados en la Organización y que son descritos, en cada caso, en el correspondiente documento Alcance y Contexto del SGI, debiendo ser conocida y cumplida por todo el personal involucrado en la operación y mantenimiento de los mismos.

2 ALCANCE

Los documentos referentes al marco normativa de la ISO 27001:2022 de SPIKA TECH, y los documentos en torno a la normativa NIST 800-171.

3 NORMATIVA APLICABLE

Es aplicable toda la normativa establecida en el documento de **RGS_1 NORMATIVA APLICABLE.xlsx.**, que se actualizara de forma periódica Las Políticas, Normas y Procedimientos dentro del alcance del SGSI, se actualizarán, si procede, en base a los cambios normativos que pudieran afectar.

4 TERMINOLOGÍA

Se incluyen a continuación términos, definiciones y acrónimos necesarios para el correcto entendimiento de este documento y que por tanto pueden precisar de aclaración.

TÉRMINO	DEFINICIÓN
0 Day (Zero Day) (Ataques Día Cero)	Son aquellas vulnerabilidades en sistemas o programas informáticos que son únicamente conocidas por determinados atacantes y son desconocidas por los fabricantes y usuarios. Al ser desconocidas por los fabricantes, no existe un parche de seguridad para solucionarlas. Por esta razón son muy peligrosas ya que el atacante puede explotarlas sin que el usuario sea consciente de quees vulnerable.
Accesibilidad o Disponibilidad de la Información	Se refiere a los medios, mecanismos y alternativas comunicativas y técnicas que posibilitan el acceso a la comunicación e información de toda la población y de un modo especial a las personas con limitaciones sensoriales, cognitivas y/o físicas y a las personas mayores. Se considera como medios de comunicación e información no sólo a aquellos que tienen como finalidadla comunicación personal e interpersonal, sino también los que tienen por finalidad la comunicación con el medio y el entorno, incluyendo los medios de comunicación de masas como son prensa, radio y t televisión. Los Sistemasde Comunicación y de acceso a la Información deberán configurarse y/o proyectarse de tal manera que permitana todos los usuarios emitir y recibir información independientemente del grado de discapacidad, edad uotra limitación.
Accesos autorizados	Autorizaciones concedidas a un usuario para la utilizaciónde los diversos recursos.
Acciones Legales	Persecución legal de la justicia o de la decisión en virtudde la ley.

TÉRMINO	DEFINICIÓN
Accionistas	Aquellos con un interés en los logros de una organización. Ejemplo: clientes, socios, empleados, surtidores, accionistas, dueños, gobierno y reguladores.
Aceptación del riesgo	Decisión de aceptar un riesgo.
ACLs	(Access Control List). Tabla que utilizan los sistemas para conocer los derechos de acceso que cada usuario poseepara un objeto determinado, como directorios, ficheros, puertos, etc. Técnicas para limitar el acceso a los recursos según la información de autenticidad y las normas de acceso.
Acreditación	Acción de facultar a un sistema o red de información paraque procese datos sensibles, determinando el grado en el que el diseño y la materialización de dicho sistemacumplen los requerimientos de seguridad técnicapreestablecidos.
Actividad	Las medidas principales tomadas para operar el proceso.
Activo	Bienes, recursos o derechos de los que dispone la empresa,los cuales representan el valor de la misma.
	Cualquier cosa que tiene valor para la organización.
	Recursos de los sistemas de información o relacionados con éstos, necesarios para que la organización funcione correctamente y alcance los objetivos propuestos por su dirección.
Activo de información	Información o sistema relacionado con el tratamiento de la misma que tenga valor para la organización, pueden ser: procesos de negocio, datos, aplicaciones, equipos informáticos, soportes de información, redes, equipamiento auxiliar o instalaciones. Es susceptible de ser atacado deliberada o accidentalmente con consecuencias para la organización.

TÉRMINO	DEFINICIÓN
Activo Tecnológico Fijo	Equipo o dispositivo inventariado como propio de una determinada posición de trabajo, incluyéndose las estaciones de trabajo, terminales o dispositivos usados poruno o varios individuos en horarios variados para ejecutar diferentes funciones computacionales, entrada de datos, etc.
Activo Tecnológico Móvil	Equipo o dispositivo que puede ser transportado y utilizadoen diferentes lugares con facilidad.
Acuerdo	Decisión tomada en común por varias personas,pudiendo estar en junta, asamblea tribunal.
Acuerdo de Licencia	Cesión de derechos entre un titular de derechos depropiedad intelectual (licenciante) y otra persona que recibe la autorización de utilizar dichos derechos (licenciatario) a cambio de un pago convenido de antemano (tasa o regalía) o de unas condiciones determinadas. Existen distintos tipos de acuerdos de licencias que pueden clasificarse en las siguientes categorías: • Acuerdos de licencia tecnológica. • Acuerdos de licencia y acuerdos e franquicia sobre marcas. • Acuerdos de licencia sobre derecho de autor.
Activo Tecnológico	Mainframes, Servidores, Desktops, Dispositivos Portátiles, Elementos de Redes, Impresoras y equipos similares a estos, así como los equipos diseñados, desarrollados y montados en fábrica.
Acuerdo de Nivel deServicio (SLA)	Un acuerdo de nivel de servicio o ANS (en inglés Service Level Agreement o SLA), es un contrato escrito entre un proveedor de servicio y su cliente con objeto de fijar el nivel acordado para la calidad de dicho servicio. El ANS es una herramienta que ayuda a ambas partes a llegar a un consenso en términos del nivel de calidad del servicio, en aspectos tales como tiempo de respuesta, disponibilidad horaria, documentación disponible, personal asignado al servicio, etc.

TÉRMINO	DEFINICIÓN
Accesibilidad o Disponibilidad de laInformación	Se refiere a los medios, mecanismos y alternativas comunicativas y técnicas que posibilitan el acceso a la comunicación e información de toda la población y de un modo especial a las personas con limitaciones sensoriales, cognitivas y/o físicas y a las personas mayores. Se considera como medios de comunicación e información no sólo a aquellos que tienen como finalidadla comunicación personal e interpersonal, sino también losque tienen por finalidad la comunicación con el medio yel entorno, incluyendo los medios de comunicación de masas como son prensa, radio y televisión. Los Sistemas de Comunicación y de acceso a la Información deberán configurarse y/o proyectarse de tal manera que permitana todos los usuarios emitir y recibir información independientemente del grado de discapacidad, edad uotra limitación.
Actualización de Seguridad	(ver Parche de Seguridad).
Administración Electrónica (eAdministración)	Actividad consistente en la prestación de servicios a ciudadanos y empresas mediante la utilización de medios telemáticos y definida en la Ley 11/2007 de 22 de junio de acceso electrónico de los ciudadanos a los servicios públicos. Esta actividad compete a las Administraciones Públicas con el objeto de simplificar los procedimientos con la Administración, manteniendo al mismo tiempo, los niveles adecuados de seguridad jurídica y procurando lamejora de calidad de los servicios. Entre las principales finalidades que persigue la Administración Electrónica se encuentran: • El impulso en la utilización de las nuevas tecnologías de la información y lascomunicaciones. • La búsqueda de transparencia y confianza por parte de ciudadanos y empresas. • La simplificación en los procedimientos y trámites administrativos. • El impulso en el crecimiento y desarrollo de la Sociedad de la Información

TÉRMINO	DEFINICIÓN
Administración de la configuración	El control de cambios realizados a un conjunto decomponentes de la configuración a lo largo del ciclo de vida del sistema.
Administración del desempeño	La capacidad de administrar cualquier tipo de medición incluyendo mediciones de empleados, equipo, proceso, operativas o financieras. El término denota un control deciclo cerrado y la vigilancia periódica de la medición.
Administrador de sistemas	Aquella persona que se dedica a mantener y operar un sistema de cómputo ó una red.
ADSL	(Asymmetric Digital Subscriber Line) Consiste en una línea digital de alta velocidad apoyada en el par trenzado de cobre que lleva la línea telefónica convencional o línea de abonado.
Adware (malvertsing)	Software que durante su funcionamiento despliega publicidad de distintos productos o servicios. Programa que automáticamente va mostrando publicidad al usuario durante su instalación o durante suuso y con ello genera beneficios a sus creadores. Aunque se asocia al malware, no tiene porqué serlo forzosamente,ya que puede ser un medio legítimo usado por desarrolladores de software que lo implementan en susprogramas. Se convierte en malware en el momento enque empieza a recopilar información sobre el ordenadordonde se encuentra instalado.
Alerta	Señal o aviso de un peligro.

TÉRMINO	DEFINICIÓN
Algoritmo de Cifrado	Operación o función matemática utilizada en combinación con una clave que se aplica a un texto en claro y permite obtener un texto cifrado (o descifrarlo) garantizando la confidencialidad e integridad de la información contenida. Existen dos tipos de cifrado atendiendo a las características de las claves de cifrado,estos son el cifrado simétrico y cifrado asimétrico. • El cifrado simétrico, también conocido como cifrado de clave secreta, es la técnica más antigua y en ella se utiliza la misma clave para cifrar y descifrar la información. • El cifrado asimétrico, o cifrado de clave pública, esuna técnica de codificación que utiliza un par declaves diferentes para el cifrado y descifrado de información
Afectado	Persona física titular de los datos que sean objeto deltratamiento automatizado de cualquier naturaleza.
Agencia Española De Protección De Datos (A.E.P.D.)	Ente de derecho público, con personalidad jurídica propia y plena capacidad pública y privada, que actúa con plena independencia de las administraciones públicas en el ejercicio de sus funciones.
AGR	Análisis y gestión de riesgos.
Agujero de Seguridad	(ver vulnerabilidad)
Amenaza	Una potencial causa de un incidente no deseado, el cual puede ocasionar un daño a un sistema o a la organización. Eventos que pueden desencadenar un incidente en la organización, produciendo daños materiales o pérdidas inmateriales en sus activos.
Análisis	Examen detallado de una cosa para conocer sus características o cualidades o su estado, y extraer conclusiones.
Análisis Forense	Conjunto de técnicas destinadas a extraer información valiosa de un sistema sin alterar el estado del mismo. Enconcreto de los discos del sistema.

TÉRMINO	DEFINICIÓN
Análisis de amenazas	Una evaluación del tipo, alcance y naturaleza de los incidentes o acciones que pueden resultar en consecuencias adversas; identificación de las amenazas que existen contra los activos de información y la tecnología de información. El análisis de amenazas suele definir también el nivel de amenaza y la probabilidad de que esta se materialice.
Análisis de causa raíz	Proceso de aprendizaje a partir de las consecuencias, típicamente de los errores y problemas.
Análisis de costes y beneficios	Técnica financiera que mide el coste de implementar una solución particular y compara esto con la ventaja ofrecida por esa solución.
Análisis de criticidad	Un análisis para evaluar los recursos o las funciones de negocio a fin de identificar su importancia para la organización, y el impacto que tendrían en caso de que no sea posible concluir una función o de que no esté disponible un recurso.
Análisis de impacto	Estudio de las consecuencias que tendría una parada de X tiempo sobre la organización.
	Es un estudio para priorizar la criticidad de los recursos de información para una organización con base en los costos (o consecuencias) de eventos adversos. Se identifican amenazas a los activos y se determinan pérdidas de negocio potenciales para diferentes periodos.
Análisis del impacto de negocio	Identificación de las amenazas que acechan a los distintos componentes pertenecientes o relacionados con el sistema de información (conocidos como 'activos'); para determinar la vulnerabilidad del sistema ante esas amenazas y para estimar el impacto o grado de perjuicio que una seguridad insuficiente puede tener para la organización, obteniendo cierto conocimiento del riesgo que se corre.
Análisis de riesgos	Proceso de analizar las funciones de negocio y los efectos que una interrupción de negocio podría provocar sobre ellas.

TÉRMINO	DEFINICIÓN
Análisis de amenazas	Una evaluación del tipo, alcance y naturaleza de los incidentes o acciones que pueden resultar en consecuencias adversas; identificación de las amenazas que existen contra los activos de información y la tecnología de información. El análisis de amenazas suele definir también el nivel de amenaza y la probabilidad de que esta se materialice.
Análisis de causa raíz	Proceso de aprendizaje a partir de las consecuencias, típicamente de los errores y problemas.
Análisis de costes y beneficios	Técnica financiera que mide el coste de implementar una solución particular y compara esto con la ventaja ofrecida por esa solución.
Análisis de criticidad	Un análisis para evaluar los recursos o las funciones de negocio a fin de identificar su importancia para la organización, y el impacto que tendrían en caso de que no sea posible concluir una función o de que no esté disponible un recurso.
Análisis de impacto	Estudio de las consecuencias que tendría una parada de X tiempo sobre la organización.
	Es un estudio para priorizar la criticidad de los recursos de información para una organización con base en los costos (o consecuencias) de eventos adversos. Se identifican amenazas a los activos y se determinan pérdidas de negocio potenciales para diferentes periodos.
Análisis del impacto de negocio	Identificación de las amenazas que acechan a los distintos componentes pertenecientes o relacionados con el sistema de información (conocidos como 'activos'); para determinar la vulnerabilidad del sistema ante esas amenazas y para estimar el impacto o grado de perjuicio que una seguridad insuficiente puede tener para la organización, obteniendo cierto conocimiento del riesgo que se corre.
Análisis de riesgos	Proceso de analizar las funciones de negocio y los efectos que una interrupción de negocio podría provocar sobre ellas.

TÉRMINO	DEFINICIÓN
Análisis de Riesgos	Evaluar la criticidad y la sensibilidad de los activos de información. Un ejercicio que determina el impacto de perder el soporte de cualquier recurso de unaorganización, establece el aumento de dicha perdida con el tiempo, identifica los recursos mínimos que es necesario recuperar y prioriza la recuperación de los procesos y sistemas de soporte.
	Utilización sistemática de la información disponible, paraidentificar peligros y estimar los riesgos.
Antimalware	(ver antivirus)
Antivirus	Es un programa informático específicamente diseñado para detectar, bloquear y eliminar código malicioso (virus, troyanos, gusanos, etc.), así como proteger los equipos de otros programas peligrosos conocidos genéricamente como malware. La forma de actuar del antivirus parte de una base de datos que contiene parte de los códigos utilizados en la creación de virus conocidos. El programa antivirus compara el código binario de cada archivo ejecutablecon esta base de datos. Además de esta técnica, se valen también de procesos de monitorización de los programaspara detectar si éstos se comportan como programas maliciosos. Es importante hacer notar que, para un correcto funcionamiento del antivirus, éste debe estar activado yactualizado en todo momento.
Aplicabilidad de los Controles	Documento que lista los controles de seguridad que servirán de referencia para implementar las medidas deseguridad informática de una organización.
Aplicación	Desarrollo de código realizado en uno o varios lenguajes de programación y que nos permite llevar a cabo algunatarea o dar algún servicio.
Aplicaciones Engañosas	(Ver Malware).
Arquitectura de la información	(Ver arquitectura de TI).

TÉRMINO	DEFINICIÓN
Arquitectura de TI	Un marco integrado para evolucionar o darmantenimiento a la TI existente y adquirir nueva TI paraalcanzar las metas estratégicas y de negocio de laempresa.
Arquitectura empresarial	Mapa de rutas tecnológicas orientada al negocio para ellogro de las metas y objetivos de negocio.
Arquitectura empresarial para TI	Respuesta en la entrega de TI, provista por procesos claramente definidos usando sus recursos (aplicaciones, información, infraestructura y personas).
Artistas intérpretes o ejecutantes	Persona que represente, cante, lea, recite o interprete en cualquier forma una obra. A esta figura se asimila la dedirector de escena y de orquesta.
Ataque	Cualquier acción deliberada encaminada a violar los mecanismos de seguridad de un sistema de información.
Ataque por fuerza bruta	Intentar en repetidas ocasiones todas las posibles combinaciones de contraseñas y llaves de encriptación hasta que se encuentra la correcta.

TÉRMINO	DEFINICIÓN
Ataque Combinado	Es uno de los ataques más agresivos ya que se vale de métodos y técnicas muy sofisticadas que combinan distintos virus informáticos, gusanos, troyanos y códigos maliciosos, entre otros. Esta amenaza se caracteriza por utilizar el servidor y vulnerabilidades de Internet para iniciar, transmitir y difundir el ataque extendiéndose rápidamente y ocasionando graves daños, en su mayor parte, sin requerir intervención humana para su propagación. Las principales características que presenta este ataque son: • Los daños producidos van desde ataques de denegación de servicio (DoS), pasando por ataques enla dirección IP o daños en un sistema local; entre otros. • Tiene múltiples métodos de propagación. • El ataque puede ser múltiple, es decir, puede modificarvarios archivos y causar daños en varias áreas a la vez,dentro de la misma red. • Toma ventaja de vulnerabilidades ya conocidas en ordenadores, redes y otros equipos. • Obtiene las contraseñas por defecto para teneraccesos no autorizados. • Se propaga sin intervención humana.
Ataque Diccionario	(ver ataque de fuerza bruta)
Ataque de Repetición	Es un tipo de ataque en el cual el atacante captura la información que viaja por la red, por ejemplo un comando de autenticación que se envía a un sistema informático, para, posteriormente, enviarla de nuevo a su destinatario, si que este note que ha sido capturada. Si el sistema informático o aplicación es vulnerable a este tipo de ataques, el sistema ejecutará el comando, como si fuera legítimo, enviando la respuesta al atacante que puede así obtener acceso al sistema. Para protegerse de este tipo de ataques el sistemainformático puede tomar medidas como usar un control deidentificación de comandos, de sellado de tiempos (timestamp), etc. junto con el cifrado y la firma de los comandos con el fin de evitar que sean reutilizados.

TÉRMINO	DEFINICIÓN
Atención al usuario	El único punto de contacto dentro de la organización deTI para los usuarios de los servicios prestados por TI.
Auditoría de seguridad	Estudio y examen independiente del historial y actividades de un sistema de información, con la finalidad de comprobar la idoneidad de los controles del sistema, asegurar su conformidad con la estructura de seguridad y procedimientos operativos establecidos, a fin de detectar brechas en la seguridad y recomendar cambios en los procedimientos, controles y estructuras de seguridad.
Autenticación	El acto de verificar la identidad de un usuario y su elegibilidad para acceder a la información computarizada. La autenticación está diseñada paraproteger contra conexiones de acceso fraudulentas.
	Procedimiento de comprobación de la identidad de unusuario.
	Característica de dar y reconocer la autenticidad de los activos del dominio (de tipo información) y/o la identidad de los actores y/o la autorización por parte de los autorizadores, así como la verificación de dichas tres cuestiones.
Autenticidad	(ver no Repudio).
Autor	Persona natural que crea alguna obra literaria, artística ocientífica.
Autorización	Permiso para una acción o actividad.
Autoridad de Certificación	Procedimiento para comprobar que alguien es quién diceser cuando accede a un ordenador o a un servicio online. Este proceso constituye una funcionalidad característicapara una comunicación segura.
Autoridad de Registro	Es la entidad encargada de identificar de manera inequívoca a los usuarios para que, posteriormente, éstos puedan obtener certificados digitales.

TÉRMINO	DEFINICIÓN
Autoridad de validación	Entidad que informa de la vigencia y validez de loscertificados electrónicos creados y registrados por una Autoridad de Registro y por una Autoridad de Certificación. Asimismo, las autoridades de validación almacenan la información sobre los certificados electrónicos anulados en las listas de revocación de certificados (CRL). Resumiendo, el proceso, cuando un cliente consulta el estado en que se encuentra un certificado electrónico a una autoridad de validación, ésta comprueba en su CRL el estado del mismo, contestando mediante el protocolo detransferencia de hipertexto HTTP. Actualmente, en España son autoridades de validación: • La Fábrica Nacional de Moneda y Timbre presta sus servicios de validación con carácter universal: ciudadanos, empresas y Administraciones Públicas. • La plataforma @firma del Ministerio de Administraciones Públicas presta los servicios devalidación al conjunto de las Administraciones Públicas.

TÉRMINO	DEFINICIÓN
Aviso Legal	Un aviso legal es un documento, en una página web, donde se recogen las cuestiones legales que son exigidaspor la normativa de aplicación. El aviso legal puede incluir: 1. Términos y condiciones de uso 2. Política de privacidad y protección de datos si recogen datos de carácter personal según la LOPD (formularios, registro de usuarios,…) 3. Información general a la que se hace referencia en al artículo 10 de la LSSI-CE y otra información relativa al uso de cookies, contratación, etc. si aplicara. 4. Qué elementos están sujetos a los derechos de propiedad intelectual e industrial, entre otros: • La propia información de la web • El diseño gráfico • Las imágenes • El código fuente • Las marcas • Los nombres comerciales • El diseño del sitio web
Backdoor	(ver puerta trasera)
Backup	Copia de seguridad que se realiza sobre ficheros o aplicaciones contenidas en un ordenador con la finalidadde recuperar los datos en el caso de que el sistema de información sufra daños o pérdidas accidentales de los datos almacenados. Los dispositivos más empleados para llevar a cabo la técnica de backup pueden ser discos duros, discos ópticos, USB o DVD. También es común la realización de copias deseguridad mediante servicios de copia basados en la nube.Es de suma importancia mantener actualizada la copia de seguridad así como tener la máxima diligencia de su resguardo, para evitar pérdidas de información que pueden llegar a ser vitales para el funcionamiento ya seade una empresa, institución o de un contenido de tipo personal. Además, cada cierto tiempo es conveniente comprobar que la copia de seguridad puede restaurarse con garantías.

TÉRMINO	DEFINICIÓN
Base de Datos de Conocimiento	Tipo especial de base de datos para la gestión del conocimiento. Provee los medios para la recolección, organización y recuperación computacional del conocimiento.
Baseline	Línea Base de Seguridad que constituye la configuraciónque debe tener el dispositivo y cuya modificación suponeuna aprobación por parte del Comité de Seguridad y la creación de la nueva baseline con dicha modificación.
Biometría	La biometría es un método de reconocimiento de personas basado en sus características fisiológicas (huellasdactilares, retinas, iris, cara, etc.) o de comportamiento (firma, forma de andar, tecleo, etc.). Se trata de un procesosimilar al que habitualmente realiza el ser humano reconociendo e identificando a sus congéneres por su aspecto físico, su voz, su forma de andar, etc. Para la identificación del individuo es necesario que los rasgos o características analizadas sean de carácter universal, ser lo suficientemente distintas a las de otra persona, permanecer de forma constante e invariante enel individuo y además, poder ser medida.
Blog	Es una bitácora en un sitio web que incluye, a modo de diario personal de su autor o autores, contenidos de su interés, actualizados con frecuencia y a menudocomentados por los lectores.
Bloqueo de datos	La identificación y reserva de los datos de carácterpersonal con el fin de impedir su tratamiento.

TÉRMINO	DEFINICIÓN
Bluetooth	Es una especificación industrial para Redes Inalámbricas deÁrea Personal que posibilita la transmisión de voz y datosentre diferentes dispositivos mediante un enlace porradiofrecuencia en la banda ISM de los 2.4 GHz. Es una tecnología inalámbrica de radio de corto alcance, cuyo objetivo es eliminar los cables en las conexiones entre dispositivos electrónicos, simplificando así las comunicaciones entre teléfonos móviles, ordenadores, cámaras digitales y otros dispositivos informáticos operandobajo la banda de radio de 2.4 GHz de frecuencia. Este protocolo ofrece a los dispositivos la posibilidad de comunicarse cuando se encuentran a una distancia de hasta 10 metros, incluso a pesar de que pueda existir algúnobstáculo físico o a pesar de que los usuarios de los dispositivos se encuentren en distintas habitaciones de un mismo emplazamiento. Algunas aplicaciones de los dispositivos Bluetooth son: • Intercambio de ficheros, fichas de contacto, recordatorios. • Comunicación sin cables entre ordenadores ydispositivos de entrada y salida (impresoras, teclado, ratón). • Conexión a determinados contenidos en áreaspúblicas.
Bomba lógica	Trozo de código insertado intencionalmente en un programa informático que permanece oculto hasta cumplirse una o más condiciones pre programadas, momento en el que se ejecuta una acción maliciosa. La característica general de una bomba lógica y que lo diferencia de un virus es que este código insertado se ejecuta cuando una determinada condición se produce, por ejemplo, tras encender el ordenador una serie de veces, o pasados una serie de días desde el momento enque la bomba lógica se instaló en nuestro ordenador.
Bot (equivalente a Robot)	(ver Zombie).

TÉRMINO	DEFINICIÓN
Botnet	Una botnet es un conjunto de ordenadores (denominados bots) controlados remotamente por un atacante quepueden ser utilizados en conjunto para realizar actividades maliciosas como envío de spam, ataques de DDoS, etc. Lasbotnets se caracterizan por tener un servidor central (C&C, de sus siglas en inglés Command & Control) al que se conectan los bots para enviar información y recibir comandos. Existen también las llamadas botnets P2P que se caracterizan por carecer de un servidor C&C único.
Buffer Overflow	(ver Desbordamiento de Buffer)
Bug (error de software)	Es un error o fallo en un programa de dispositivo o sistemade software que desencadena un resultado indeseado.
Bulo	También llamados hoax, son noticias falsas creadas para su reenvío masivo ya sea a través de redes sociales, mensajería instantánea o correo electrónico, con el fin de hacer creeral destinatario que algo es falso. Pueden ser varias las motivaciones para crear este tipo de noticias, como difundir información falsa en perjuicio de terceras personas u organismos o incitar al receptor del mensaje a causar daños en su propio ordenador.
Cadena de Custodia	Procedimiento controlado que se aplica a los indicios materiales relacionados con el delito, desde su localización hasta su valoración por los encargados de su análisis, y quetiene como fin evitar alteraciones, sustituciones, contaminaciones o destrucciones. Documento escrito que garantiza la autenticidad, seguridad, preservación e integridad de la evidencia física hallada, obtenida o recolectada y examinada.
Capacidad	Contar con los atributos necesarios para realizar o lograr.
Carding	Uso no autorizado de la tarjeta de crédito, cuentabancaria y otra información financiera de una víctima.

TÉRMINO	DEFINICIÓN
Cartas Nigerianas (estafa nigeriana)	Se trata de una comunicación inesperada mediante correo electrónico carta o mensajería instantánea en lasque el remitente promete negocios muy rentables. La expectativa de poder ganar mucho dinero mediante unas sencillas gestiones, es el gancho utilizado por los estafadores para involucrar a las potenciales víctimas en cualquier otra situación engañosa, procurando que finalmente transfiera una fuerte cantidad de dinero para llevar a cabo la operación. El funcionamiento es muy variado, pero a grandes rasgos se podría resumir así: Un remitente desconocido contacta con la potencial victima haciéndose pasar por un abogado, familiar o amigo cercano de un miembro del Gobierno o de un importante hombre de negocios que ha perdido la vida enun accidente o similar. Según esta comunicación, antes de morir esa persona, depositó una gran cantidad de dineroen una cuenta bancaria. El remitente asegura que tiene acceso legal a esa cuenta y pretende transferir el dinero auna cuenta en el extranjero. El remitente ha encontrado el nombre y la dirección de lavíctima por recomendación de otra persona o por casualidad y la víctima es la única persona de confianza que puede ayudarle a realizar la transferencia del dinero. Por su asistencia, promete a la víctima, un porcentaje de lacantidad total de dinero y solicita discreción para llevar acabo el negocio. La víctima debe abrir una cuenta en un banco determinado para que pueda remitirle el dinero y generalmente pagar por adelantado unos gastos para la transferencia del dinero. La siguiente fase del fraude consiste en convencer a la victima de que la transferencia de dinero está en proceso. Para ello, mandan a la víctima documentos aparentemente oficiales, al igual que cartas y movimientos bancarios falsos. Sin embargo, esta transferencia del dinero por parte de losestafadores nunca llega a tener lugar.
Categorización	Es la capacidad de clasificar de manera ordenada y porcategoría una o varias informaciones.
Centro de control	Alberga las reuniones de recuperación cuando semanejan operaciones de recuperación de desastre.

TÉRMINO	DEFINICIÓN
Centro de respaldo	Un centro de respaldo es un centro de procesamiento de datos (CPD) específicamente diseñado para tomar el control de otro CPD principal en caso de contingencia. Las características de un centro de respaldo deben ser las siguientes: • Su localización debe ser totalmente distinta a la del CPD principal con el objeto de que no se vean ambos afectados simultáneamente por la misma contingencia. Es habitual situarlos entre 20 y 40 kilómetros del CPD principal. • El equipamiento electrónico e informático del centro de respaldo debe ser absolutamente compatible con el existente en el CPD principal. • El equipamiento software debe ser idéntico al existente en el CPD principal. Esto implica exactamente las mismas versiones y parches del software de base y de las aplicaciones corporativas que estén en explotación en el CPD principal. De otramanera, no se podría garantizar totalmente la continuidad de operación. • Por último, es necesario contar con una réplica de los mismos datos con los que se trabaja en el CPD original.
CEO	Director ejecutivo.
Certificación	Confirmación del resultado de una evaluación, y que los criterios de evaluación utilizados fueron correctamente aplicados.
Certificado de Autenticidad	El Certificado de autenticidad (COA) es una etiqueta especial de seguridad que acompaña a un software con licencia legal para impedir falsificaciones. El COA suele ir pegado en el embalaje del software, y permite asegurar que el software y los demás elementos que contenga, como los medios y los manuales, son auténticos. En ocasiones el software viene preinstalado al comprar un equipo. En esos casos el COA suele encontrarse en el exterior del equipo. Si se trata de un dispositivo pequeño (con una longitud o anchura de 15 cm o menos), el COA puede encontrarse bajo la batería.

TÉRMINO	DEFINICIÓN
Certificado Digital	Un certificado digital es un fichero informático generado por una entidad denominada Autoridad Certificadora (CA)que asocia unos datos de identidad a una persona física, organismo o empresa confirmando de esta manera su identidad digital en Internet. El certificado digital es válido para autenticar la existenciay validez de un usuario o sitio web por lo que es necesariala colaboración de un tercero que sea de confianza para cualquiera de las partes que participe en la comunicación.El nombre asociado a esta entidad de confianza es Autoridad. Certificadora pudiendo ser un organismo público o empresa reconocida en Internet. El certificado digital tiene como función principal autenticar al poseedor pero puede servir también para cifrar las comunicaciones y firmar digitalmente. En algunas administraciones públicas y empresas privadas es requerido para poder realizar ciertos trámites que involucren intercambio de información sensible entre las partes.
Cesión o Comunicación de datos	Toda revelación de datos realizada a una persona distintadel interesado.
Chacha20-Poly1305	Es un código criptográfico de autenticación de mensajes(MAC)
Ciclo de Vida de Desarrollo Software	Es una secuencia estructurada y bien definida de las etapas a lo largo de las cuales se debe ir desarrollando unproducto software.
Cifrado	Codificar el contenido de los mensajes usando una clavepara, entre otros usos, autenticar la identidad de los usuarios, autenticar transacciones bancarias, proteger laintegridad de transferencias electrónicas y el sigilo de comunicaciones personales y comerciales. (ver Algoritmo de Cifrado)
Cifrar Datos/ Comunicaciones	Alterar los datos, tanto localizados en un sitio como los queviajan a través de las comunicaciones, de forma que nosean legibles para quienes no deben tener acceso a ellos, aunque intenten su intercepción.

TÉRMINO	DEFINICIÓN
CFO	Director financiero.
CIO	Director de información [algunas veces director detecnología (CTO, por sus siglas en inglés)].
CISO	Responsable de seguridad de la información.
Clasificación de la información	Acción o efecto de ordenar o disponer la información atendiendo a unos criterios determinados. También es laacción o efecto de dar carácter secreto o reservado a undocumento.
Cláusula	Disposición de un contrato o cualquier otro documentosimilar, público o privado, que expresa alguna condición.
Clave Pública	O bien, estructura de clave pública, de un par de claves, denominadas clave pública y clave privada, que tienen lapeculiaridad de que los mensajes cifrados con una de ellassólo pueden ser descifrados utilizando la otra. Así, se conoce como clave pública a una de estas claves,que puede ponerse en conocimiento de todo el mundo y que utilizará un remitente para cifrar el mensaje o documento que quiere enviar, garantizando de esta forma que tan solo pueda descifrarlo el destinatario con su clave privada.
Claves de Acceso (Credencial de Acceso)	Conjunto de informaciones que son utilizadas en el proceso de autorización de acceso de un empleado o de unsistema. Las claves de acceso pueden estar compuestas por: • Usuario – Nombre atribuido a la parte de la clave de acceso que identifica al empleado, • Contraseña de acceso – Parte de la clave de acceso utilizada por el empleado o sistema. Está compuesto por un conjunto de caracteres secretos (password) de conocimiento solamente los usuarios o sistemas paraautenticar su acceso. • Componente de carácter biométrico (iris, digitales, reconocimiento de voz, etc.). OTP (One-Time-Password) – Dispositivo capaz de generar contraseñas aleatorias. Esta funcionalidad puede integrase a los sistemas para fortalecer el proceso de autenticación.

TÉRMINO	DEFINICIÓN
Clave Privada	Los sistemas de criptografía asimétrica, se basan en la generación de un par de claves, denominadas clave pública y clave privada, que tienen la peculiaridad de que los mensajes cifrados con una de ellas sólo pueden serdescifrados utilizando la otra. En este tipo de sistemas, la clave privada sólo debe serconocida por el usuario para el cifrado y descifrado de mensajes. El hecho de que la clave privada sólo sea conocida por supropietario persigue dos objetivos: • Cualquier documento generado a partir de esta clave necesariamente tiene que haber sido generado por el propietario de la clave (firma electrónica). • Un documento al que se aplica la clave pública sólo podrá ser abierto por el propietario de la correspondiente clave privada (cifradoelectrónico). • Estos sistemas de criptografía constituyen un elemento esencial para la propia seguridad del tráfico jurídico y el desarrollo de transacciones económicas o el comercio on-line.
Cliente	Una persona o una entidad externa o interna que recibelos servicios empresariales de TI.

TÉRMINO	DEFINICIÓN
Cloud Computing (computación en la nube)	El término cloud computing o computación en la nube serefiere a un paradigma que permite ofrecer servicios decomputación a través de una red, que usualmente es Internet. Esta tendencia permite a los usuarios almacenar información, ficheros y datos en servidores de terceros, deforma que puedan ser accesibles desde cualquier terminal con acceso a la nube o a la red, resultando de esta manera innecesaria la instalación de software adicional (al que facilita el acceso a la red) en el equipo local del usuario. Importantes plataformas ofrecen herramientas y funcionalidades de este tipo y aunque conlleva una importante dinamización y libertad, se debe prestar especial atención a la seguridad de la información, particularmente desde el punto de vista de la protecciónde la intimidad y de los datos personales, ya que la información, documentos y datos se encuentran almacenados en servidores de terceros sobre los que generalmente no se tiene control.
Código de Conducta	En el ámbito de las TIC, los códigos de conducta son aquellas recomendaciones o reglas que tienen por finalidad determinar las normas deontológicas aplicables en el ámbito de la tecnología y la informática con el objetode proteger los derechos fundamentales de los usuarios. Loscódigos de conducta se plantean en un ámbito de aplicación muy extenso, sin embargo, desde el punto de vista tecnológico e informático se puede considerar que implican la sujeción a un conjunto de normas y principioséticos cuyo uso y funcionamiento deberá garantizar la plena confianza y seguridad, evitando la vulneración de los derechos de los ciudadanos. En definitiva, un código de conducta es un conjunto de normas y obligaciones que asumen las personas y entidades que se adscriben al mismo y mediante las cuales se pretende fomentar la confianza y la seguridad jurídica, así como una mejor tramitación de cualquier problema oincidencia.

TÉRMINO	DEFINICIÓN
Código Malicioso	Tipo de programa (desde un troyano hasta un spyware) quetiene como objetivo infiltrarse o dañar el ordenador sin el conocimiento de su dueño y con finalidades muy diversas.
COBIT	Objetivos de Control para la Información y las Tecnologías Relacionadas, la serie internacional de objetivos de controlde TI que publica el IT Governance Institute, 2005, 2000, 1998, 1996.
Comité directivo	Un comité administrativo conformado para apoyar yadministrar varios proyectos, tales como un programa de seguridad de información.
Comité estratégicode TI	Comité al nivel del Consejo Directivo para garantizar queel consejo participe en las principales decisiones del tema de TI.
Comité de seguridad y salud	Órgano paritario y colegiado de participación destinadoa la consulta regular y periódica de las actuaciones de laempresa en materia de prevención de riesgos.
Componente de la configuración (CI)	Componente de una infraestructura—o un artículo, como una solicitud de cambio, asociado con una infraestructura—la cual está (o estará) bajo el control de laadministración de configuraciones. Los CIs pueden variar ampliamente en complejidad, tamaño y tipo, desde un sistema completo (incluyendo todo el hardware, software y documentación) hasta un solo módulo o un componente menor de hardware.
Computación en la Nube	(ver Cloud Computing)
Comprobación	Verificación de algo que haya tenido lugar.
Comunicación comercial	Toda forma de comunicación dirigida a la promoción, directa o indirecta, de la imagen o de los bienes o serviciosde una empresa, organización o persona que realice unaactividad comercial, industrial, artesanal o profesional.
Condición de trabajo	Cualquier característica del mismo que pueda tener unainfluencia significativa en la generación de riesgos para la seguridad y la salud del trabajador.
Confidencialidad	Propiedad de la información por la que ésta no se muestra disponible o revelada para individuos, entidades o procesos no autorizados.

TÉRMINO	DEFINICIÓN
	La protección de información privada o sensible contra divulgación no autorizada.
	Característica que previene contra la divulgación noautorizada de activos del dominio.
Conexión Segura	Conexión que utiliza un protocolo de cifrado para la transmisión de datos, p.ej.: HTTPS o SSH.
Confidencialidad	Confidencialidad es la propiedad de la información, por laque se garantiza que está accesible únicamente a personal autorizado a acceder a dicha información. Requisito básico de seguridad que garantiza que sólo laspersonas, entidades, o procesos autorizados puedenacceder a la información contenida en los sistemas. La confidencialidad de la información constituye la piedraangular de la seguridad de la información. Junto con la integridad y la disponibilidad suponen las tres dimensiones de la seguridad de la información.
Confidencialidad de la Información	(ver Confidencialidad)
Configuración	Conjunto de atributos, parámetros y características quepermiten modelar un sistema acorde a sus valores.
Consentimiento del interesado	Toda manifestación de voluntad, libre, inequívoca, específica e informada mediante la que el interesado consiente el tratamiento de datos personales que le conciernen.
Consumidor	Toda persona física o jurídica en los términos establecidos en el artículo 1 de la Ley 26/1984, de 19 de julio, Generalpara la Defensa de los Consumidores y Usuarios.
Contención	Acción de reprimir o encerrar dentro de sí algo.
Continuidad	Prevenir, mitigar y recuperarse de una interrupción. Lostérminos “planear la reanudación del negocio”, “planear la recuperación después de un desastre” y “planear contingencias” también se pueden usar en este contexto; todos se concentran en los aspectos de recuperación dela continuidad.

TÉRMINO	DEFINICIÓN
Continuidad de negocio	Capacidad táctica y estratégica, PRE-aprobada por la gestión de una organización, para planear y responder a incidentes y a interrupciones de negocio para continuar con las operaciones de negocio en un aceptable nivel predefinido.
Contrato	Convenio o pacto, ya sea oral o escrito, entre partes queaceptan ciertas obligaciones y derechos sobre una materia determinada. El documento que refleja las condiciones de este acuerdo también recibe el nombre de contrato.
Contrato electrónico	Todo contrato en el que la oferta y la aceptación se transmiten por medio de equipos electrónicos de tratamiento y almacenamiento de datos, conectados a una red de telecomunicaciones.
Contramedida	Cualquier proceso que reduce directamente una amenaza o vulnerabilidad.
Contraseña	Información confidencial, frecuentemente constituida por una cadena de caracteres, que puede ser usada en la autenticación de un usuario.
Control/es	Medios de gestión del riesgo, que incluyen políticas, procedimientos, directrices, prácticas o estructuras de la organización, y que pueden ser de naturaleza administrativa, técnica, de gestión o legal.
	Las políticas, procedimientos, prácticas, dispositivos y estructuras organizacionales diseñadas para brindar unacerteza razonable de que se alcanzarán los objetivos denegocio y que los eventos no deseados se prevendrán, obien, se detectarán y corregirán.
	Las políticas, procedimientos, prácticas y estructuras organizacionales diseñadas para proporcionar una garantía razonable de que los objetivos del negocio se alcanzarán y los eventos no deseados serán prevenidos odetectados.
Control administrativo	Las reglas, procedimientos y prácticas que están relacionados con la efectividad operativa, la eficiencia y el cumplimiento con las regulaciones y las políticasadministrativas.

TÉRMINO	DEFINICIÓN
Control aplicativo	Un conjunto de controles integrados dentro de las soluciones automatizadas (aplicaciones).
Control de acceso	Mecanismo que en función de la identificación yaautenticada permite acceder a datos o recursos.
	Las reglas, procedimientos, prácticas y dispositivos cuyoobjetivo es prevenir la entrada o el derecho de uso no autorizado, ya sea físico o electrónico.
	El proceso que limita y controla el acceso a los recursos deun sistema computacional; un control lógico o físico diseñado para brindar protección contra la entrada o el uso no autorizados.
Control de detección	Un control que se usa para identificar eventos (indeseables o deseados), errores u otras ocurrencias con efectomaterial sobre un proceso o producto final, de acuerdo alo definido por la empresa.
Control general	También control general de TI. Un control que se aplica al funcionamiento general de los sistemas de TI de la organización y a un conjunto amplio de soluciones automatizadas (aplicaciones).
Control interno	Las políticas, procedimientos, prácticas y estructuras organizacionales diseñadas para brindar una garantía razonable de que los objetivos del negocio se alcanzarány de que los eventos indeseables serán prevenidos o detectados y corregidos.
Control Parental (control paterno)	Conjunto de herramientas o medidas que se pueden tomar para evitar que los menores de edad hagan un usoindebido del ordenador, accedan a contenidos inapropiados o se expongan a riesgos a través de Internet. Estas herramientas tienen la capacidad de bloquear, restringir o filtrar el acceso a determinados contenidos o programas, accesibles a través de un ordenador o de la red, y de dotar de un control sobre el equipo y las actividades que se realizan con él, a la persona que sea eladministrador del mismo, que normalmente deberá ser el padre o tutor del menor.

TÉRMINO	DEFINICIÓN
Control preventivo	Un control interno que se usa para prevenir eventos indeseables, errores u otras ocurrencias que pudieran tener un efecto material negativo sobre un proceso o producto final, de acuerdo a la organización.
Convenio	Acuerdo que se desarrolla en función de un asunto específico.
Copia de respaldo	Copia de los datos de un fichero automatizado en unsoporte que posibilite su recuperación.
COSO	Comité de organizaciones patrocinadoras de la Comisión Treadway. Estándar aceptado a nivel internacional para elgobierno corporativo. Ver www.coso.org.
Cookie	Una cookie es un pequeño fichero que almacena información enviada por un sitio web y que se almacenaen el equipo del usuario, de manera que el sitio web puedeconsultar la actividad previa del usuario. Sus principalesfunciones son: • Llevar el control de usuarios: cuando un usuario introduce su nombre de usuario y contraseña, se almacena una cookie para que no tenga que estar introduciéndolas para cada página del servidor. • Recabar información sobre los hábitos de navegación del usuario. Esto puede significar un ataque contra laprivacidad de los usuarios y es por lo que hay que tener cuidado con ellas.
Cortafuegos (firewall)	Sistema de seguridad compuesto o bien de programas (software) o de dispositivos hardware situados en los puntos limítrofes de una red que tienen el objetivo de permitir y limitar, el flujo de tráfico entre los diferentes ámbitos que protege sobre la base de un conjunto de normas y otros criterios. La funcionalidad básica de un cortafuego es asegurar que todas las comunicaciones entre la red e Internet se realicen conforme a las políticas de seguridad de la organización o corporación. Estos sistemas suelen poseer características de privacidady autentificación.

TÉRMINO	DEFINICIÓN
Credencial de Acceso	Conjunto de informaciones que son utilizadas en el proceso de autorización de acceso de un empleado o de un sistema. Las credenciales de acceso pueden estar compuestas por: a. Usuario – Nombre atribuido a la parte de la credencial de acceso que identifica al empleado, b. Contraseña de acceso – Parte de la credencial de acceso utilizada por el empleado o sistema. Está compuesto por un conjunto de caracteres secretos(password) de conocimiento solamente los usuarios o sistemas para autenticar su acceso. c. Componente de carácter biométrico (iris, digitales, reconocimiento de voz, etc.). OTP (One-Time-Password) – Dispositivo capaz de generar contraseñas aleatorias. Esta funcionalidad puede integrase a los sistemas para fortaleces el proceso de autenticación.
Criptografía	La criptografía es la técnica que consiste en cifrar un mensaje, conocido como texto en claro, convirtiéndolo enun mensaje cifrado o criptograma, que resulta ilegible para todo aquel que no conozca el sistema mediante el cual hasido cifrado. Existen dos tipos principales de criptografía: por un lado, la conocida como criptografía simétrica, más tradicional, y la criptografía asimétrica o de clave pública.
CSF	Factor crítico de éxito.
CSO	Director o responsable de seguridad corporativa.
Curve25519	Es una curva elíptica que ofrece 128 bits de seguridad y sediseñó de acuerdo al esquema de la Curva elíptica Diffie-Hellman.
Daños derivados del trabajo	Enfermedades, patologías o lesiones sufridas con motivo uocasión del trabajo.
Dato disociado	Aquél que no permite la identificación de un afectado o interesado.
Datos de carácter personal	Cualquier información concerniente a personas físicas identificadas o identificables.

TÉRMINO	DEFINICIÓN
Datos de carácter personal relacionadoscon la salud	Las informaciones concernientes a la salud pasada, presente y futura, física o mental, de un individuo. En particular, se consideran datos relacionados con la saludde las personas los referidos a su porcentaje de discapacidad y a su información genética.
Debian	Organización formada por voluntarios dedicada a desarrollar software libre y promocionar los ideales de la comunidad del software libre.
DCO	Objetivos de control detallados. Los DCOs son componentes de un objetivo de control en particular.
Declaración de la aplicabilidad	Declaración documentada que describe los objetivos delcontrol y los controles que son relevantes y aplicables al SGSI de la organización.
Defacement	Deformación o cambio producido de manera intencionada en una página web, por un atacante que haya obtenido algún tipo de acceso a ella, bien por algúnerror de programación de la página, por algún bug en elpropio servidor o por una mala administración de este.
Degradación	Pérdida de valor de un activo como consecuencia de la materialización de una amenaza.

TÉRMINO	DEFINICIÓN
Denegación de Servicio (DDos, Ataquede Denegación de Servicio)	Se entiende como denegación de servicio, en términos deseguridad informática, a un conjunto de técnicas que tienen por objetivo dejar un servidor inoperativo. Mediante este tipo de ataques se busca sobrecargar un servidor y de esta forma impedir que los usuarios legítimos puedan utilizarlos servicios por prestados por él. El ataque consiste en saturar con peticiones de servicio alservidor, hasta que éste no puede atenderlas, provocandosu colapso. Un método más sofisticado es el ataque de Denegación de Servicio Distribuido (DDoS), mediante el cual las peticiones son enviadas, de forma coordinada entre varios equipos, que pueden estar siendo utilizados para este fin sin el conocimiento de sus legítimos dueños (por ejemplo, a través de una botnet). Esto puede ser así mediante el uso de programas malware que permitan la toma de control del equipo de forma remota, como puede ser en los casos de ciertos tipos de gusano o bien porque el atacante se ha encargado de entrar directamente en el equipo de la víctima.
Denegación Distribuida de Servicio (DDoS)	(ver DDoS)
Delegado de prevención	Representantes de los trabajadores con funciones específicas en materia de prevención de riesgos laborales.
Derecho compensatorio	Derecho por copia privada que compensa los derechos de propiedad intelectual dejados de percibir por razón delas reproducciones de las obras o prestaciones protegidas para uso exclusivamente privado del copista.
Derecho de acceso	Privilegio que otorga la ley al interesado para solicitar y obtener gratuitamente información de sus datos de carácter personal sometidos a tratamiento, el origen de dichos datos, así como las comunicaciones realizadas o que se prevén hacer de los mismos.

TÉRMINO	DEFINICIÓN
Derecho de cancelación	Privilegio que otorga la ley al interesado para solicitar al responsable del tratamiento de sus datos de carácter personal, el bloqueo de los mismos. El responsable del fichero conservará los datos bloqueados únicamente a disposición de las administraciones públicas, jueces y tribunales, para la atención de las posibles responsabilidades nacidas del tratamiento durante el plazo de prescripción de éstas.
Derecho de explotación	Son aquellos derechos que cede el autor cuando lleva a cabo la explotación económica de su obra y que no pueden realizarse sin su consentimiento salvo en los casosprevistos en la Ley de Propiedad Intelectual.
Derecho de oposición	Privilegio que otorga la ley al interesado para oponerse altratamiento de sus datos de carácter personal, en aquelloscasos en los que no es necesario recabar su consentimiento.
Derecho de rectificación	Privilegio que otorga la ley al interesado para solicitar lacorrección de sus datos de carácter personal sometidos a tratamiento, por resultar ser inexactos o incompletos para los fines declarados, o bien por no ajustarse a lo dispuestopor la legislación vigente.
Derecho de remuneración	Aquellos que obligan al titular al pago de una cantidad dineraria por los actos de explotación que realice, cantidad esta que es determinada, bien por la ley o en sudefecto por las tarifas generales de las entidades de gestión.
Derecho exclusivo	Aquellos que permiten a su titular autorizar o prohibir losactos de explotación de su obra o prestación protegida por el usuario, y a exigir de este una retribución a cambio de la autorización que le conceda.
Derecho moral	Son aquellos que permiten al titular entre otros, decidir si suobra ha de ser divulgada, y en qué forma, exigir el respetoa la integridad de la misma o retirar la obra del comerciopor cambio de convicciones intelectuales o morales. No son transmisibles.
Desarrollo de Software	Conjunto código realizando con una finalidad.

TÉRMINO	DEFINICIÓN
Desbordamiento de Búfer (Buffer overflow)	Es un tipo de vulnerabilidad muy utilizada con la que se persigue conseguir acceso remoto al sistema atacado. Undesbordamiento de búfer intenta aprovechar defectos enla programación que provocan un error o el cuelgue del sistema. Un desbordamiento de búfer provoca algo similara lo que ocurre cuando llenamos un vaso más allá de su capacidad: éste se desborda y el contenido se derrama. Cuando el programador no incluye las medidas necesarias para comprobar el tamaño del búfer en relación con el volumen de datos que tiene que alojar, se producetambién el derramamiento de estos datos que se sobrescriben en otros puntos de la memoria, lo cual puede hacer que el programa falle. El atacante calcula qué cantidad de datos necesita enviary dónde se reescribirán los datos, para a continuación enviar comandos que se ejecutarán en el sistema. Este tipo de vulnerabilidad, dado que se produce por undefecto en el código del programa, sólo puede ser solventada mediante las actualizaciones o parches del programa en cuestión. Por esta razón es imprescindible mantener actualizados todos los programas instalados en nuestros equipos y servidores.
Desempeño	La implantación real o el logro de un proceso.
Destinatario o cesionario	La persona física o jurídica, pública o privada u órgano administrativo, al que se revelen los datos.
Destinatario del servicio	Persona física o jurídica que utiliza, sea o no por motivos profesionales, un servicio de la sociedad de la información.
Detección de intrusos	El proceso de monitorear los eventos que ocurren en unsistema o red informática para detectar señales deaccesos no autorizados o ataques.
DH-2048	Diffie-Hellman de 2048 bits.
Diccionario de datos	Un conjunto de meta-datos que contiene definiciones y representaciones de elementos de datos.
Diccionario de datos empresarial	El nombre, tipo, rango de valores, fuente, sistema de registro, y autorización de acceso para cada elemento dedatos utilizado en la empresa. Indica cuáles programas aplicativos usan esos datos, de tal forma que cuando se contemple una estructura de datos, se pueda generar unalista de los programas afectados.

TÉRMINO	DEFINICIÓN
Diffie-Hellman	Protocolo criptográfico de establecimiento de claves entre partes que no han tenido contacto previo, utilizando un canal inseguro, y de manera anónima (no autentificada).
Difusión de la Información	Proceso por el cual se hace llegar al usuario la informaciónque necesita o por el que se le da la posibilidad de obtenerla.
Dimensión	(de seguridad) Un aspecto, diferenciado de otros posibles aspectos, respecto del que se puede medir el valor de unactivo en el sentido del perjuicio que causaría su pérdidade valor.
Dirección IP (IP)	Las direcciones IP (del acrónimo inglés IP para Internet Protocol) son un número único e irrepetible con el cual seidentifica a todo sistema conectado a una red. Podríamos compararlo con una matrícula en un coche. Así, una dirección IP (o simplemente IP) en su versión v4 es unconjunto de cuatro números del 0 al 255 separados por puntos. Por ejemplo: 192.168.121.40 En su versión v6, las direcciones IP son mucho más complejas, siendo hasta 4 veces más largas, más seguras ypermitiendo un gran número de sistemas conectados a Internet. Un ejemplo es el siguiente: 2001:0db8:3c4d:0015:0000:0000:1a2f:1a2b Las direcciones IP pueden ser «públicas», si son accesibles directamente desde cualquier sistema conectado a Internet o «privadas», si son internas a una red LAN y solo accesibles desde los equipos conectados a esa red privada.
Dirección MAC (MAC. Dirección física, Dirección hardware)	Una dirección MAC, también conocida como dirección física, es un valor de 48 bits único e irrepetible que identifica todo dispositivo conectado a una red. Cada dispositivo tiene su propia dirección MAC determinada que es única a nivel mundial ya que es escrita directamente, en formabinaria, en el hardware del interfaz de red en el momentode su fabricación. El acrónimo MAC hace referencia a Media Access Control que traducido al español significa Control de Acceso al Medio.

TÉRMINO	DEFINICIÓN
Directriz	Una descripción que clarifica lo que se debería hacer y cómo, para conseguir los objetivos establecidos en las políticas.
	La descripción de un modo particular de lograr algo, lacual es menos descriptiva que un procedimiento.
Disociación	Todo tratamiento de datos personales de modo que la información que se obtenga no pueda asociarse a persona identificada o identificable.
Disponibilidad	Propiedad de ser accesible y utilizable a demanda de unaentidad autorizada.
	Garantizar que los sistemas de información y los datos estén listos para su uso cuando se les necesita; a menudo se expresa como el porcentaje de tiempo que se puede utilizar un sistema para trabajo productivo.
	Característica que previene contra la denegación noautorizada de acceso a activos del dominio.
Dispositivo	Elemento hardware que permite realizar alguna función enla red.
Dispositivo portátil	Son equipos de procesado de información que tienen capacidad de almacenar datos, establecer conexiones externas e interactuar con otros sistemas y redes, además de ser fácilmente transportables debido a sus pequeñasdimensiones y peso, p.ej.: teléfonos inteligentes y tabletas.
Divulgación	Acción y efecto de difundir, promover o publicar algo paraponerlo al alcance de otras personas.
DMZ	La zona búfer entre la Internet y la red privada que tieneuna ingeniería que utiliza en los firewalls y otros dispositivos para evitar el acceso de partes externas a los sistemas internos.
	Zona DesMilitarizada. En seguridad informática, una zona desmilitarizada (DMZ) o red perimetral es una red local (una subred) que se ubica entre la red interna de una organización y una red externa, generalmente Internet.

TÉRMINO	DEFINICIÓN
Documentos controlados	Son todos aquellos documentos en los que un sistema degestión asegura la adecuación y puesta al día de los mismos.
Documentos No controlados	Son todos aquellos documentos de los que no se asegurasu puesta al día.
Dominio	Agrupación de objetivos de control en etapas lógicas enel ciclo de vida de inversión en TI.
e-Administración	(ver Administración Electrónica)
Ed25519	Sistema de firma de clave pública
Ejercicio	Actividad en la cual el plan de la continuidad del negociose ensaya en parte o de manera completa para asegurarse de que el plan contiene la información apropiada y produce el resultado deseado cuando está ejecutado.
Empleado	Empleado o recurso de SPIKA con vínculo contractual.
Empresa	Un grupo de individuos que trabajan juntos para un fin común, por lo general dentro del contexto de una formaorganizacional, como una corporación agencia pública, entidad de caridad o fondo.
Encargado de tratamiento	Persona física o jurídica, autoridad pública, servicio o cualquier otro organismo que, sólo o conjuntamente conotros, trate datos personales por cuenta del responsabledel tratamiento.
Entidades de gestión colectiva de derechos de propiedad intelectual	Organizaciones privadas de base asociativa y naturalezano lucrativa que se dedican en nombre propio o ajeno ala gestión de derechos de propiedad intelectual de carácter patrimonial por cuenta de sus legítimos titulares.
Entidades de radiodifusión	Personas jurídicas bajo cuya responsabilidad organizativa y económica se difunden emisiones o transmisiones.
Erradicación	Eliminación o supresión completa y definitiva de una cosa.
Error	Mal funcionamiento o mala actuación en algo o dealguien

TÉRMINO	DEFINICIÓN
Error de Software	(ver Bug)
Equipo de trabajo	Cualquier máquina, aparato, instrumento o instalaciónutilizada en el trabajo.
Equipos de protección individual	Cualquier equipo destinado a ser llevado o sujetado por eltrabajador para que le proteja de uno o varios riesgos que puedan amenazar su seguridad o su salud en el trabajo, asícomo cualquier complemento o accesorio destinado a talfin.
Esquema de clasificación de datos	Un esquema empresarial para clasificar los datos porfactores tales como criticidad, sensibilidad y propiedad.
Estado de riesgo	Caracterización de los activos por su riesgo residual; es decir lo que puede pasar tomando en consideración las salvaguardas desplegadas.
Estafa Nigeriana	(ver Cartas Nigerianas)
Estándar	Una práctica de negocio o producto tecnológico que es una práctica aceptada, avalada por la empresa o por el equipo gerencial de TI. Los estándares se pueden implantar para dar soporte a una política o a un proceso,o como respuesta a una necesidad operativa. Así como las políticas, los estándares deben incluir una descripciónde la forma en que se detectará el incumplimiento.
Estatuto de auditoría	Documento que define el propósito, la autoridad y la responsabilidad de la actividad de auditoría interna,aprobado por el consejo.
Estrategia de continuidad denegocio	Acercamiento de una organización que asegurará su recuperación y continuidad ante la aparición de un desastre u otro incidente mayor o interrupción de negocio.
Evaluación de salvaguardas	Evaluación de la eficacia de las salvaguardas existentes enrelación al riesgo que afrontan.
Evaluación del riesgo	Un proceso que se utiliza para identificar y evaluar los riesgos y su posible impacto en la organización en términos cuantitativos o cualitativos.
	Procedimiento basado en el análisis del riesgo paradeterminar si se ha conseguido un riesgo tolerable.

TÉRMINO	DEFINICIÓN
Evaluación por comparación (Benchmarking)	Un proceso utilizado en administración, en particular en la administración estratégica, en el cual las compañíasevalúan varios aspectos de sus procesos de negocio conrespecto a las mejores prácticas, por lo general dentro de su propia industria.
Evento de seguridad de la información	Una ocurrencia identificada de un sistema, servicio o redindicando una posible ruptura de la política de seguridadde la información o fallo de las salvaguardas, o una situación previamente conocida que pueda ser importante desde el punto de vista de la seguridad.
Evidencia	Certeza manifiesta que resulta innegable y que no sepuede dudar.
Examinación forense	El proceso de recopilar, evaluar, clasificar y documentar la evidencia digital para ayudar a la identificación de un delincuente y el método utilizado para poner en peligro.
Exostar	Exostar se creó para ayudar a las empresas a satisfacer sus requisitos más exigentes para el acceso y el intercambio deaplicaciones e información, tanto dentro como fuera de lasfronteras corporativas. www.exostar.com
Exploit	Secuencia de comandos utilizados para, aprovechándosede un fallo o vulnerabilidad en un sistema, provocar un comportamiento no deseado o imprevisto. Mediante la ejecución de exploit se suele perseguir: - el acceso a un sistema de forma ilegítima obtención de permisos de administración en un sistema ya accedido, - un ataque de denegación de servicio a un sistema.
Exportador de	La persona física o jurídica, pública o privada, u órgano administrativo situado en territorio español y responsable del tratamiento de los datos de carácter personal que son objeto de transferencia internacional a un país tercero.
Exposición al riesgo	Cantidad total de riesgo que una organización estápreparada para aceptar, tolerar, o estar expuesta en cualquier momento a tiempo.
Falsos Positivos	Hallazgos o pruebas que se consideran verdaderas peroque luego se muestran falsas.

TÉRMINO	DEFINICIÓN
Fichero automatizado	Todo conjunto organizado de datos de carácter personalque sean objeto de un tratamiento automatizado, cualquiera que fuere la forma o modalidad de su creación, almacenamiento, organización y acceso.
Firewall	Un sistema o una combinación de sistemas que impone una barrera entre dos o más redes que por lo regular forman una barrera entre un ambiente seguro y uno abierto, como la Internet.
Firewall Personal	Cortafuegos que actúa para proteger el equipo delusuario de la red y que está instalado en su propio equipo.
Firma electrónica (firma digital)	La firma electrónica (o digital) se define como el conjuntode datos electrónicos que acompañan o que están asociados a un documento electrónico. Esta firma se basa en la Ley 59/2003, de 19 de Diciembre, donde se indica quela «firma electrónica» reconocida debe cumplir las siguientes propiedades o requisitos: • identificar al firmante. • verificar la integridad del documento firmado. • garantizar el no repudio en el origen. • contar con la participación de un tercero de confianza. • estar basada en un certificado electrónicoreconocido. Debe de ser generada con un dispositivo seguro de creación de firma Una firma electrónica de un documentose consigue calculando el valor «hash» del documento yadjuntándolo al final del mismo, para a continuación cifrarlo con la clave pública de la persona a la que enviaremos el documento. De esta manera nadie pueda leerlo más que el receptor.
Firmware	Programa informático que establece la lógica de más bajonivel que controla los circuitos electrónicos de un dispositivo de cualquier tipo.

TÉRMINO	DEFINICIÓN
Formatear Disco Duro	Realizar un conjunto de operaciones informáticas, independientes entre sí, físicas o lógicas, que permiten establecer un disco duro, una memoria USB, una partición del disco duro o de la memoria USB o cualquier otro dispositivo de almacenamiento de datos a su estado original, u óptimo para ser reutilizado o reescrito con nuevainformación. Esta operación puede borrar, aunque no deforma definitiva, los datos contenidos en él.
Forward Secrecy	Propiedad de los sistemas criptográficos que garantiza que el descubrimiento de las claves utilizadas actualmente nocompromete la seguridad de las claves usadas con anterioridad (no las revela).
Frame Relay	Es una técnica de comunicación mediante retransmisiónde tramas, introducida por la ITU-T a partir de la recomendación I.122 de 1988. Consiste en una forma simplificada de tecnología de conmutación de paquetes que transmite una variedad de tamaños de tramas o marcos (“frames”) para datos, perfecto para la transmisiónde grandes cantidades de datos.
Frecuencia	Tasa de ocurrencia de una amenaza.
Fuentes accesibles al público	Son exclusivamente el censo promocional, los repertorios telefónicos y las listas de personas pertenecientes a grupos profesionales que contengan únicamente los datos de nombre, título, profesión, actividad, grado académico, dirección e indicación de su pertenencia al grupo, así como los diarios y boletines oficiales y los medios de comunicación. Perderán el carácter de fuentes accesibles, si son editadas en forma de libro u otro soportefísico, con la nueva edición que se publique, y en caso de obtenerse telemáticamente una copia en formato electrónico, al año de su obtención.
Fuga de Datos	La fuga de datos o fuga de información es la pérdida de la confidencialidad de la información privada de una persona o empresa. Información que, a priori, no debería ser conocida más que por un grupo de personas, en el ámbito de una organización, área o actividad, y que termina siendo visible o accesible para otros.
Gateway	(ver proxy)

TÉRMINO	DEFINICIÓN
Gmail	Es un servicio de correo electrónico con posibilidades POP3e IMAP gratuito proporcionado por la empresa estadounidense Google, Inc.
Gerencia	Persona o grupo de personas que dirigen y controlan una organización desde el del más alto nivel.
Gestión contínua del ciclo de vida del negocio	Una serie de actividades continuas de negocio las cuales cubren colectivamente todos los aspectos y las fases de la programación de gestión continúa de negocio.
Gestión de la continuidad de negocio	Proceso de gestión integral que identifica las amenazas potenciales en una organización y los impactos a operaciones de negocio que esas amenazas, si se realizan,podrían causar, y el cual proporciona un marco para construir una organización resistente con la capacidad deuna respuesta efectiva que salvaguarde el interés de susclaves, reputación, marca y el valor creativo.
Gestión de riesgos	Selección e implantación de las medidas o salvaguardas de seguridad adecuadas para conocer, prevenir, impedir, reducir o controlar los riesgos identificados y así reducir al mínimo su potencialidad o sus posibles perjuicios. La gestión de riesgos se basa en los resultados obtenidos en elanálisis de los riesgos.
Gobierno	El método por medio del cual una organización es dirigida, administrada o controlada.
Gusano (worm)	Un programa auto replicable que no se adhiere a programas, sino que se propaga en forma independientea las acciones de los usuarios. Los gusanos son, en efecto,ataques programados a redes.
Hardware	Conjunto de elementos físicos o materiales que constituyen una computadora, un sistema informático, o un dispositivo de comunicaciones.

TÉRMINO	DEFINICIÓN
Hash (función resumen)	Función criptográfica que se basa en un algoritmo matemático que transforma cualquier bloque arbitrario de datos en una nueva serie de caracteres con una longitudfija.
Hoax (bulo)	(ver bulo)
Hot site	Un sitio externo completamente operativo para el procesamiento de datos equipado con software de sistemas y hardware para su uso en caso de un desastre.
Hosting	Servicio de alojamiento de las páginas web que gestionan empresas especializadas. Las empresas que se dedican aeste servicio son como los hoteleros de la red: ofrecen espacio para que otras compañías almacenen cualquier información que quieran que sea accesible por una red, desde sus páginas web hasta la información de su red interna o Intranet.
Housing	Alquiler de un espacio físico de un centro de datos paraubicar los equipos informáticos de la empresa
Identificación	Procedimiento de reconocimiento de la identidad de unusuario.
Impacto	Consecuencia evaluada de un resultado particular.
	Consecuencia que sobre un activo tiene la materializaciónde una amenaza.
Impacto residual	Impacto remanente en el sistema tras la implantación de las salvaguardas determinadas en el plan de seguridad de la información.
Importador de datos personales	La persona física o jurídica, pública o privada, u órgano administrativo receptor de los datos en caso de transferencia internacional de los mismos a un tercer país, ya sea responsable del tratamiento, encargada del tratamiento o tercero.
Incidencia	Cualquier anomalía que afecte o pudiera afectar a laseguridad de los datos.
Incidencia de seguridad	Cualquier anomalía que afecte o pueda afectar a laseguridad de la información.

TÉRMINO	DEFINICIÓN
Incidente	La situación que pudo ser, o podría conducir a, una interrupción del negocio, una interrupción, una pérdida,un incidente de emergencia o una crisis.
	Evento con consecuencias en detrimento de la seguridaddel sistema de información.
Incidente de seguridad de la información	Un único o una serie de eventos de seguridad no deseados ni esperados que tienen una significativa probabilidad decomprometer el funcionamiento del negocio y amenazar la seguridad de la información.
Información	Datos que poseen significado.
Información Clasificada	Es un tipo de información sensible que está restringida porlas leyes o regulada para clases particulares de personas. Se requiere una habilitación formal de seguridad para manejar y acceder a documentos clasificados.
Información Sensible	Información cuya divulgación no autorizada o mal uso pueda suponer un daño o peligro para la organización.
Informática Forense	La informática forense consiste en un proceso de investigación de los sistemas de información para detectar toda evidencia que pueda ser presentada como prueba fehaciente en un procedimiento judicial. Para esta investigación se hace necesaria la aplicación detécnicas científicas y analíticas especializadas que permitan identificar, preservar, analizar y presentar datos que sean válidos dentro de un proceso legal. Entre las técnicas mencionadas se incluyen reconstruir el sistema informático, examinar datos residuales y explicar lascaracterísticas técnicas del uso aplicado a los datos y bienes informáticos. Su implementación debe llevarse a cabo considerando lodispuesto por la normativa legal aplicable, a efectos de novulnerar los derechos de protección de datos y de intimidad de terceros. Los principales objetivos de la informática forense son: Utilización de técnicas que garanticen la seguridad de lainformación corporativa, como medida preventiva. Reunir las evidencias electrónicas como medio probatoriopara detectar el origen de un ataque. Garantizar los requerimientos técnicos y jurídicos de lossistemas de seguridad de la información.

TÉRMINO	DEFINICIÓN
Informe	Exposición oral o escrita sobre el estado de una cosa o unapersona, sobre las circunstancias que rodean un hecho, etc.
Informe de insuficiencias	Informe: ausencia o debilidad de las salvaguardas que aparecen como oportunas para reducir el riesgo sobre elsistema.
Infraestructura	La tecnología, los recursos humanos y las instalaciones quepermiten el procesamiento de las aplicaciones.
Infraestructura de Clave Pública (PKI)	También conocido por las siglas PKI (del inglés Public Key Infrastructure), una infraestructura de clave pública es un conjunto de elemento Hardware, Software, políticas y procedimientos de actuación encaminados a la ejecución con garantías de operaciones de cifrado y criptografía, tales la firma, el sellado temporal o el no repudio de transacciones electrónicas.
Ingeniería Social	Las técnicas de ingeniería social son tácticas utilizadas para obtener información datos de naturaleza sensible, en muchas ocasiones claves o códigos, de una persona. Estas técnicas de persuasión suelen valerse de la buena voluntad y falta de precaución de la víctima.
Instrucciones de trabajo	Documento en el que se ofrecen detalles prácticos (operativos y claros) sobre lo que se debe realizar para llevar a cabo una tarea específica y según las responsabilidades asignadas.
Integridad	Propiedad de salvaguardar la exactitud y la completitudde los activos.
	Cuan precisa, completa y valida es la información.
	Característica que previene contra la modificación odestrucción no autorizadas de activos de la organización.
Integridad de la información	(ver integridad)
Internet	Conjunto descentralizado de redes de comunicación interconectadas que utilizan la familia de protocolosTCP/IP, lo cual garantiza que las redes físicas heterogéneas que la comparten formen una red lógica única de alcance mundial.

TÉRMINO	DEFINICIÓN
Interoperabilidad	Capacidad que tiene un producto o sistema, cuyas interfaces son totalmente conocidas, para funcionar con otros productos o sistemas existentes o futuros y eso sin restricción de acceso o de implementación.
Interrupción de negocio	Evento anticipado (Ej. una huelga de servicio público) oinesperado (Ej. un apagón o terremoto), el cual interrumpeel curso normal de las operaciones de negocio.
Inventario	Asiento detallado de los bienes (tangibles e intangibles), derechos y deudas que una persona o una entidadposeen a una fecha determinada.
Inventario de Software	Asiento detallado de los activos software con los quecuenta la organización o empresa.
Investigacion	Actividad orientada a la obtención de nuevos conocimientos y su aplicación para la solución de algo.
Invocación	Acto de declarar que el plan de la continuidad delnegocio de una organización necesita ser ejecutado paracontinuar la entrega de productos críticos o de servicios.
Inyección SQL (SQL Injection)	Es un tipo de ataque que se aprovecha de una vulnerabilidad en la validación de los contenidos introducidos en un formulario web y que puede permitir la obtención de forma ilegítima de los datos almacenados en la base de datos del sitio web, entre ellos las credenciales de acceso.
IP	(ver Dirección IP)
IPSec	Abreviatura en inglés de Internet Protocol security, es unconjunto de protocolos cuya función es asegurar las comunicaciones sobre el Protocolo de Internet (IP) autenticando y/o cifrando cada paquete IP en un flujo dedatos. IPsec también incluye protocolos para el establecimiento de claves de cifrado.

TÉRMINO	DEFINICIÓN
ISO/IEC 17799	Emitido originalmente como parte de la Norma Británica para la Seguridad de Información en 1999 y luego como el Código de Práctica para la Gerencia de Seguridad de Información en octubre de 2000, recibió la categoría de código internacional de práctica para la gerencia de seguridad de información por parte de la Organización Internacional para la Estandarización (ISO). Esta norma define los controles de disponibilidad, integridad y confidencialidad de la información en un sistema integralpara la gerencia de la seguridad de información. La versión más reciente es ISO/IEC 17799:2005.
ISO/IEC 27001	Una norma internacional, emitida en 2005, sobre la gerencia de la seguridad de la información que se basa en ISO/IEC 17799 y define un conjunto de principios orientadores con respecto a la confidencialidad, integridad y disponibilidad de la información.
ISO/IEC 9001:2000	Código de práctica para la administración de la calidad de la Organización internacional para la Estandarización (ISO). El ISO 9001:2000 especifica los requisitos para un sistema de administración de calidad para cualquier organización que necesite demostrar su habilidad para ofrecer productos de manera consistente que satisfagan al cliente, a los requisitos regulatorios aplicables y que desee aumentar la satisfacción del cliente.
ITIL	Librería de infraestructura de TI de la oficina de gobierno gubernamental del reino unido (OGC). Un conjunto de lineamientos sobre la administración y procuración de servicios operativos de TI.
KGI	Indicador clave de meta.
KPI	Indicador clave de desempeño.
LAN	(Local Area Network) Es la interconexión de variosordenadores y periféricos.
Libsodium	LibSodium es una librería para cifrado, descifrado, firmas,contraseñas “hashing”, etc.
LinkedIn	LinkedIn es una comunidad social orientada a lasempresas, a los negocios y el empleo.
Linux	Open code operating system.

TÉRMINO	DEFINICIÓN
Linux Debian	Linux by Debian Community
LOPDGDD	Ley Orgánica 3/2018, de 5 de diciembre, de Protección deDatos Personales y garantía de los derechos digitales.
LPRL	Ley que determina el cuerpo básico de garantías yresponsabilidades preciso para establecer un adecuado nivel de protección de la salud de los trabajadores frentea los riesgos derivados de las condiciones de trabajo, y elloen el marco de una política coherente, coordinada y eficaz de prevención de los riesgos laborales.
Madurez	Indica el grado de confiabilidad o dependencia que el negocio puede tener en un proceso, al alcanzar las metasy objetivos deseados.
Malvertising	(ver Adware)
Malware	Abreviatura de “Malicious Software” en inglés, se trata de cualquier programa cuyo objetivo sea causar daños a ordenadores, sistemas o redes y, por extensión, a sus usuarios
Manual de calidad Y seguridad	Describe el sistema de gestión de calidad y seguridad deuna organización.
Mapa de riesgos	Informe: relación de las amenazas a que están expuestoslos activos.
Marcador depuntuación balanceado	Un método para medir las actividades de una empresa entérminos de su visión y estrategias, proporcionando unavista rápida e integral del desempeño del negocio a la gerencia. Es una herramienta administrativa cuyo fin es medir un negocio desde las siguientes perspectivas:financiera, del cliente, del negocio y del aprendizaje.
Marco de control	Una herramienta para los dueños de los procesos de negocio que facilita la descarga de sus responsabilidadesa través de la procuración de un modelo de control de soporte.
Marco de trabajo	Ver marco de control.
Marco Normativo de la Seguridad de la Información	Conjunto de documentos de seguridad de la informacióndesarrollado e implantado por SPIKA y que está compuesto por tres niveles: políticas, normativas y procedimientos.

TÉRMINO	DEFINICIÓN
Material	De una escala o de una significación que amenazaríanobjetivos claves de una organización si no ocurrieran.
Mecanismos de Control	Conjunto de disposiciones y prácticas específicas para hacer seguimiento y evaluación del comportamiento de un sistema o elemento específico.
Memoria "Flash"	Dispositivo en forma de tarjeta orientado a realizar el almacenamiento de grandes cantidades de datos,permitiendo la lectura y escritura de múltiples posiciones dememoria en la misma operación.
Menor privilegio	Los empleados deben tener los derechos de acceso necesarios para el desarrollo de sus funciones y solamente estos. Cuanto mayor es la exposición, mayores son los riesgos asociados a ella.
Metadatos	Los metadatos son el conjunto de datos relacionados con un documento y que recogen información fundamentalmente descriptiva del mismo, así como información de administración y gestión. Los metadatos es una información que enriquece el documento al que está asociado. A modo de ejemplo, se podría considerar como una analogía al uso de índices que se emplean en una biblioteca, donde gracias a datos del tipo: autor, títulos, etcétera se nos permite localizar un libro en concreto. Otro ejemplo de uso es mejorar las consultas en los buscadores consiguiendo una mayor exactitud y precisión en los resultados.
Métrica	Un estándar para medir el desempeño contra la meta.
Métrica de seguridad	Una forma de medición que se utiliza para determinar cualquier aspecto de la operación de cualquier actividad relacionada con la seguridad.
Modelo de madurezde la capacidad (CMM)	El modelo de madurez de la capacidad para software (CMM), del Instituto de Ingeniería de Software (SEI), es un modelo utilizado por muchas organizaciones para identificar las mejores prácticas, las cuales son convenientes para ayudarles a evaluar y mejorarla madurez de su proceso de desarrollo de software.
Modelo de valor	Caracterización del valor que representan los activos para la organización, así como de las dependencias entre los diferentes activos.

TÉRMINO	DEFINICIÓN
Nacl	Es una librería “software” para las comunicaciones de red,cifrado, descifrado, firmas, etc.
No Repudio	El no repudio en el envío de información a través de las redes es capacidad de demostrar la identidad del emisorde esa información. El objetivo que se pretende es certificarque los datos, o la información, provienen realmente de la fuente que dice ser. El problema del control de autenticidad dentro de los sistemas de información a través de la Red, en relación tanto de la identidad del sujeto como del contenido de losdatos, puede ser resuelto mediante la utilización de la firmaelectrónica (o digital).
Norma	Una métrica utilizada para determinar la exactitud de una cosa o proceso; un conjunto de reglas o especificaciones que, consideradas en conjunto, definen un dispositivo desoftware o hardware. Una norma es también una base reconocida para comparar y medir algo.
Nivel de seguridadalto	Medidas de seguridad exigibles para todos aquellos ficheros que contengan datos de ideología, afiliación sindical, religión, creencias, origen racial, salud o vida sexual, así como los que contengan datos recabados parafines policiales sin consentimiento de las personas afectadas.
Nivel de seguridad básico	Medidas de seguridad exigibles para todos aquellosficheros que contengan datos de carácter personal.
Nivel de seguridad medio	Medidas de seguridad exigibles para todos aquellos ficheros que contengan datos relativos a la comisión de infracciones administrativas o penales, hacienda pública,servicios financieros y servicios de información sobre solvencia patrimonial y crédito, así como todos aquellosdatos de carácter personal que permitan emitir unaevaluación de la personalidad del individuo.
Normas	Documento externo a la empresa donde se establecenrequisitos aplicables a una organización.
Objetivo de control	Un estatuto del resultado o propósito que se desea alcanzar al implantar procedimientos de control en un proceso en particular.

TÉRMINO	DEFINICIÓN
Oficina de Seguridad	Área o departamento que tiene como misión articular y gestionar la seguridad de la información en una organización.
Objetivo del Tiempo de Recuperación (RTO)	Tiempo fijado para la reasunción de la entrega delproducto, del servicio o de la actividad después de un incidente.
	Tiempo establecido para la recuperación de una funcióno recurso de negocio después de que ha ocurrido un desastre.
Objetivo mínimo de continuidad de negocio	Nivel mínimo de servicios y/o productos que es aceptable por la organización para conseguir sus objetivos denegocio durante una interrupción.
OLA	Acuerdo a nivel operativo. Un acuerdo interno que cubrela prestación de servicios que da soporte a la organización de TI en su prestación de servicios.
OneDrive	Es un servicio de alojamiento de archivos.
Operating System	Conjunto de códigos para la gestión y comunicación de instrucciones del usuario: escritura de datos, lectura de datos, lectura de datos del disco duro, control de uso dememoria, ejecución de otros programas, etc.
Orden de Compra	Documento que emite el comprador para pedir mercaderías al vendedor, indica cantidad, detalle, precioy condiciones de pago, entre otras cosas. El documentooriginal es para el vendedor e indica que debe preparar elpedido.
Organización	La manera en que una empresa está estructurada.
	Negocio o administración formada por un particular.
Parche de Seguridad (actualización de seguridad)	Un parche de seguridad es un conjunto de cambios que se aplican a un software para corregir errores de seguridad en programas o sistemas operativos. Generalmente los parches de seguridad son desarrollados por el fabricantedel software tras la detección de una vulnerabilidad en el software y pueden instalarse de forma automática o manual por parte del usuario.

TÉRMINO	DEFINICIÓN
Pendrive	Denominado también lápiz de memoria. Es un dispositivo de almacenamiento que utiliza memoria “flash” para guardar datos e información.
Pentest (pentesting,test de penetración,prueba de penetración)	Una prueba de penetración es un ataque a un sistema software o hardware con el objetivo de encontrar vulnerabilidades. El ataque implica un análisis activo de cualquier vulnerabilidad potencial, configuracionesdeficientes o inadecuadas, tanto de hardware como de software, o deficiencias operativas en las medidas de seguridad. Este análisis se realiza desde la posición de un atacante potencial y puede implicar la explotación activa de vulnerabilidades de seguridad. Tras la realización del ataque se presentará una evaluaciónde seguridad del sistema, indicando todos los problemasde seguridad detectados junto con una propuesta de mitigación o una solución técnica. La intención de una prueba de penetración es determinarla viabilidad de un ataque y el impacto en el negocio de un ataque exitoso.
Período tolerablemáximo de la interrupción	La duración máxima después de la cual la viabilidad de una organización será amenazada irrevocablemente si el producto y la entrega del servicio no pueden ser reasumidos.
Pharming	Ataque informático que aprovecha una vulnerabilidad delsoftware de los servidores DNS y que consiste en modificar o sustituir el archivo del servidor de nombres de dominiocambiando la dirección IP legítima de una entidad (comúnmente una entidad bancaria) de manera que en el momento en el que el usuario escribe el nombre de dominio de la entidad en la barra de direcciones, el navegador redirigirá automáticamente al usuario a una dirección IP donde se aloja una web falsa que suplantarála identidad legítima de la entidad, obteniéndose de forma ilícita las claves de acceso de los clientes la entidad.

TÉRMINO	DEFINICIÓN
Phishing (vishing,smishing, spear phising)	Uso de un tipo de ingeniería social, caracterizado por intentar adquirir información confidencial de forma fraudulenta, como puede ser información detallada sobretarjetas de crédito, una contraseña u otra información bancaria.
Plan de contingencia	Un Plan de Contingencia de las Tecnologías de la Información y las Comunicaciones (TIC) consiste en una estrategia planificada en fases, constituida por un conjunto de recursos de respaldo, una organización de emergencia y unos procedimientos de actuación, encaminados a conseguir una restauración ordenada, progresiva y ágil de los sistemas de información que soportan la información y los procesos de negocio considerados críticos en el Plan de Continuidad de Negocio de la compañía.
Plan de continuidadde negocio (PCB)	Colección documentada de procedimientos y información que es desarrollada, compilada y mantenidapara estar preparados ante la aparición de un incidente permitiendo que una organización continúe entregando sus productos críticos y servicios.
Plan de gestión de incidentes	Plan de acción bien definido y documentado que se usa a la hora de un incidente, cubriendo típicamente las claves personales, los recursos, los servicios y las accionesque necesitan poner el proceso de gerencia en ejecucióndel incidente.
Plan de infraestructura tecnológica	Un plan para el mantenimiento y desarrollo de lainfraestructura tecnológica.
Plan de seguridad	Conjunto de programas de seguridad que permitenmaterializar las decisiones de gestión de riesgos.
Plan de recuperaciónde desastre	Una serie de recursos humanos, físicos, técnicos y de procedimientos orientados a recuperar, dentro de tiempos y costos definidos, una actividad interrumpida por una emergencia o desastre.

TÉRMINO	DEFINICIÓN
Plan estratégico deTI	Un plan a largo plazo. Ej: con un horizonte de tres a cinco años, en el cual la gerencia del negocio y de TI describe de forma cooperativa cómo los recursos de TI contribuirán a los objetivos estratégicos empresariales (metas).
Plan táctico de TI	Un plan a mediano plazo, Ej., con un horizonte de seis adieciocho meses, que traduzca la dirección del planestratégico de TI en las iniciativas requeridas, requisitos derecursos y formas en las que los recursos y los beneficiosserán supervisados y administrados.
Plazo máximo tolerablede interrupción	Tiempo necesario para que los impactos desfavorables que pudiesen surgir como consecuencia de no suministrar un producto/servicio o de no realizar una actividad, se transformen en inaceptables.
PMBOK	Cuerpo de conocimiento de administración de proyectos,un estándar para administración de proyectos desarrollado por el instituto de administración de proyectos(PMI).
PMO	Director de administración de proyectos.
Política	Declaraciones de alto nivel sobre el propósito y ladirección de la gerencia.
	Por lo general, un documento que ofrece un principio dealto nivel o una estrategia a seguir. El propósito de una política es influenciar y guiar la toma de decisiones presente y futura, haciendo que estén de acuerdo a la filosofía, objetivos y planes estratégicos establecidos por osequipos gerenciales de la empresa. Además delcontenido de la política, esta debe describir las consecuencias de la falta de cumplimiento de la misma, el mecanismo para manejo de excepciones y la manera en que se verificará y medirá el cumplimiento de la política.

TÉRMINO	DEFINICIÓN
Política de Seguridad	Son las decisiones o medidas de seguridad que una empresa ha decidido tomar respecto a la seguridad de sussistemas de información después de evaluar el valor de susactivos y los riegos a los que están expuestos. Este términotambién se refiere al documento de nivel ejecutivo mediante el cual una empresa establece sus directrices de seguridad de la información.
Portafolio	Una agrupación de programas, proyectos, servicios o activos seleccionados, administrados y vigilados para optimizar el retorno sobre la inversión.
Práctica de control	Mecanismo clave de control que apoya el logro de los objetivos de control por medio del uso responsable de recursos, la administración apropiada de los riesgos y laalineación de TI con el negocio.
Prácticas administrativas clave	Las principales prácticas administrativas que el propietario del proceso debe realizar para alcanzar las metas del proceso.
Prestadores de Servicios de la Sociedad de la Información	Toda persona física o jurídica que proporciona un servicio de la sociedad de la información.
Prevención	Conjunto de actividades o medidas adoptadas o previstasen todas las fases de actividad de la empresa con el fin deevitar o disminuir los riesgos derivados del trabajo.
PRINCE2	Proyectos en un ambiente controlado, un método de administración de proyectos que cubre la administración,el control y la organización de un proyecto.
Privacidad	Libertad contra intrusión o divulgación no autorizada deinformación sobre personas.
Problema	Causa subyacente desconocida de uno o más incidentes.
Procedimiento	Una descripción detallada de los pasos necesarios para realizar operaciones especificas conforme a las normas aplicables.

TÉRMINO	DEFINICIÓN
	Una descripción de una manera particular de lograr algo; una forma establecida de hacer las cosas; una serie de pasos que se siguen en un orden regular definido,garantizando un enfoque consistente y repetitivo hacia las actividades.
Procedimiento operativo	Documento que indica las directrices a seguir por un departamento o varios departamentos para cumplir conun requisito de la norma implantada de calidad y seguridad.
Proceso	Por lo general, un conjunto de procedimientos influenciados por las políticas y estándares de la organización, que toma las entradas provenientes de un número de fuentes, incluyendo otros procesos, manipulalas entradas, y genera salidas, incluyendo a otros procesos,para los clientes de los procesos. Los procesos tienen razones claras de negocio para existir, propietarios responsables, roles claros y responsabilidades alrededor dela ejecución del proceso, así como los medios para medirel desempeño.
Proceso alterno	Procesos manuales o automáticos diseñados y establecidos para continuar con los procesos críticos de negocio desde el punto de fallo hasta el regreso a la normalidad.
Proceso de negocio	(Ver proceso).
Productos y servicios	Actividades identificables e intangibles que son el objetoprincipal de una transacción ideada para brindar a los clientes satisfacción de deseos o necesidades.
Productores de fonogramas	Persona natural o jurídica bajo cuya iniciativa y responsabilidad se realiza por primera vez la fijación exclusivamente sonora de la ejecución de una obra o deotros sonidos.
Productores de grabacione saudiovisua le	Persona natural o jurídica que tiene la iniciativa y asume la responsabilidad de la grabación audiovisual.

TÉRMINO	DEFINICIÓN
Programa	Una agrupación estructurada de proyectos independientes que incluye el alcance completo del negocio, del proceso, de las personas, de la tecnología ylas actividades organizacionales que se requieren (tanto necesarias como suficientes) para lograr un resultado denegocios claramente especificado.
Programa aplicativo	Un programa que procesa los datos del negocio a lo largode las actividades, tales como la captura, actualización oconsulta de datos. Contrasta con los programas desistemas, tales como un sistema operativo o un programa de control de redes, y con los programas utilitarios, talescomo copiar (“copy”) o clasificar (“sort”).
Programa de ordenador	Toda secuencia de instrucciones o indicaciones destinadas a ser utilizadas, directa o indirectamente, en unsistema informático para realizar una función o una tarea o para obtener un resultado determinado, cualquiera quefuere su forma de expresión y fijación.
Programa de seguridad	Agrupación de tareas orientadas a afrontar el riesgo delsistema. La agrupación se realiza por conveniencia, bienporque se trata de tareas que en singular carecerían de eficacia, bien porque se trata de tareas con un objetivo común, bien porque se trata de tareas que competen a una única unidad de acción.
Programa de seguridad de información	La combinación total de las medidas técnicas, operativas y de procedimientos, así como las estructuras administrativas implementadas para asegurar la confidencialidad, integridad y disponibilidad de lainformación con base en los requerimientos de negocio yel análisis de riesgos.
Programa Espía	(ver Spyware)
Programación de la Gestión Continua de Negocio	Gestión en curso y proceso de gobierno llevado a cabo por gerencia y encargado de asegurar que los pasos necesarios son realizados para identificar el impactopotencial de pérdidas, mantener como viable larecuperación de las estrategias y planes, y asegurar la continuidad de productos/servicios para entrenamiento, ejercicio, mantenimiento y aseguramiento.

TÉRMINO	DEFINICIÓN
Propietarios de datos	Individuos, por lo general gerentes o directores, que tienen la responsabilidad de la integridad, el uso y el reporte preciso de los datos computarizados.
Propietario de la información	Son los directores, gerentes, o jefes de las unidades de negocio, los cuales, son responsables de la información quese genera y se utiliza en las operaciones de su unidad. El propietario de la información asigna el nivel inicial declasificación de la información.
Propiedad privada	Reconocimiento de propiedad integrado por derechos morales y de carácter patrimonial (o derechos de explotación), que atribuyen al autor la plena disposiciónsobre su obra y el derecho exclusivo a su explotación.
Protocolo	Es un sistema de reglas que permiten que dos o más entidades se comuniquen entre ellas para transmitir información por medio de cualquier tipo de medio físico. Se trata de las reglas o el estándar que define la sintaxis,semántica y sincronización de la comunicación, así comotambién los posibles métodos de recuperación de errores. Los protocolos pueden ser implementados por hardware, por software, o por una combinación de ambos.
Proveedor de Acceso (ISP)	Sociedad de la Información que proporcionan a sus usuarios/clientes acceso a redes de telecomunicaciones, tanto fijas como móviles. En inglés se denomina ISP, acrónimo de Internet Service Provider.
Proveedor de servicios	Organización externa que presta servicios a la organización.
Proxy (Gateway)	El proxy es tanto el equipo, como el software encargado ddar e servicio, que hacen de intermediario en las peticionede los equipos de las redes LAN hacia Internet. Su cometido es de centralizar el tráfico entre Internet y una re privada, de forma que se evita que cada una de las máquinade la red privada tenga que disponer necesariamente de un conexión directa a Internet y una dirección IP pública. A mismo tiempo un proxy puede proporcionar algunos mecanismos de seguridad (firewall o cortafuegos) que impiden accesos no autorizados desde el exterior hacia lared privada.

TÉRMINO	DEFINICIÓN
Proyecto	Un conjunto estructurado de actividades relacionadas con la entrega de una capacidad definida a la organización (la cual es necesaria, aunque no suficiente para lograr unresultado de negocios requerido) con base en un calendario y presupuesto acordado.
Proyecto de seguridad	Programa de seguridad cuya envergadura es tal querequiere una planificación específica.
Prueba	Argumentos y medios que pretender demostrar la verdado falsedad de algo.
Puerta Trasera	Se denomina backdoor o puerta trasera a cualquier puntodébil de un programa o sistema mediante el cual una persona no autorizada puede acceder a un sistema. Las puertas traseras pueden ser errores o fallos, o pueden haber sido creadas a propósito, por los propios autores, pero al ser descubiertas por terceros, pueden ser utilizadascon fines ilícitos. Por otro lado, también se consideran puertas traseras a losprogramas que, una vez instalados en el ordenador de lavíctima, dan el control de éste de forma remota alordenador del atacante. Por lo tanto, aunque no son específicamente virus, puedenllegar a ser un tipo de malware que funcionan como herramientas de control remoto. Cuentan con una codificación propia y usan cualquier servicio de Internet:correo, mensajería instantánea, http, ftp, telnet o chat. Chat.
Punto de recuperaciónde datos	Punto a partir del cual debe ser posible recuperar la información utilizada por una actividad, para que ésta pueda funcionar tras una interrupción.
QMS	Sistema de administración de la calidad. Un sistema quedescribe las políticas y procedimientos necesarios para mejorar y controlar los distintos procesos que al final conducirán a un desempeño mejorado del negocio.
Query	Término informático utilizado para hacer referencia a unainteracción con una base de datos.

TÉRMINO	DEFINICIÓN
Rack	Es un bastidor destinado a alojar equipamiento electrónico, informático y de comunicaciones. Sus medidas están normalizadas para que sea compatible con equipamiento de cualquier fabricante.
Ramsonware	El ciberdelincuente, toma control del equipo infectado y «secuestra» la información del usuario cifrándola, de tal forma que permanece ilegible si no se cuenta con la contraseña de descifrado. De esta manera extorsiona al usuario pidiendo un rescate económico a cambio de esta contraseña para que, supuestamente, pueda recuperar sus datos. La seguridad del sistema está basada en la dificultad defactorización de grandes números. Su funcionamiento sebasa en el envío de un mensaje cifrado mediante la clavepública del destinatario, y una vez que el mensaje cifrado llega, éste se encarga de descifrarlo con su clave privada.
RDSI	Red Digital de Servicios Integrados (RDSI o ISDN en inglés)como: una red que procede por evolución de la Red Digital Integrada (RDI) y que facilita conexiones digitalesextremo a extremo para proporcionar una amplia gamade servicios, tanto de voz como de otros tipos, y a la que los usuarios acceden a través de un conjunto de interfaces normalizados.
Recurso	Cualquier parte componente de un sistema de información.
Recursos críticos	Cualquier sistema, servicio o infraestructura de tratamiento de información o ubicaciones físicas utilizadas para su alojamiento, que posee información considerada como crítica para un proceso de negocio.
Recursos de sistemas y Red	Sistemas o recursos de Informática, plataformas y equipos de la planta de telecomunicaciones.
Red	Conjunto de equipos y sistemas interconectados quecomparten información, recursos y servicios.

TÉRMINO	DEFINICIÓN
Red de Área Local (LAN)	Es una red informática de pequeña amplitud geográfica, que suele limitarse a espacios como una oficina, una vivienda o un edificio. Una Red de Área Local permite interconectar distintos dispositivos todo tipo, ordenadores, impresoras, servidores, discos duros externos, etc. Las Redes de Área Local pueden ser cableadas o no cableadas, también conocidas como redes inalámbricas.Por término general las redes cableadas son más rápidas yseguras, pero impiden la movilidad de los dispositivos.
Red P2P	Es un modelo de comunicaciones entre sistemas o serviciosen el cual todos los nodos/extremos son iguales, tienen las mismas capacidades y cualquiera de ellas puede iniciar lacomunicación. Se trata de un modelo opuesto al cliente/servidor en dondeel servidor se encuentra a la espera de una comunicaciónpor parte del cliente. El modelo P2P se basa en que todoslos nodos actúan como servidores y clientes a la vez. Una red P2P es por tanto una red de sistemas o servicios queutiliza un modelo P2P. Todos los sistemas/servicios conectados entre sí y que se comportan como iguales conun objetivo en común. Por ejemplo las botnets P2P utilizan este modelo para evitarque haya un servidor central único fácilmente detectable.
Red Privada Virtual (VPN)	Una red privada virtual, también conocida por sus siglasVPN (Virtual Private Network) es una tecnología de red quepermite una extensión segura de una red local (LAN) sobreuna red pública o no controlada como Internet. Al establecerlas, la integridad de los datos y la confidencialidad se protegen mediante la autentificación yel cifrado. Se trata realmente de una conexión virtual punto a puntoentre dos redes LAN usando para la conexión una red pública como es Internet y consiguiendo que esta conexión sea segura gracias al cifrado de la comunicación.
Regla	Patrón que delimita lo que se puede hacer y lo que no.
Resistencia	Capacidad de una organización de resistir al ser afectadopor un incidente.

TÉRMINO	DEFINICIÓN
	La capacidad de un sistema o red para recuperarse de forma automática de una interrupción, por lo general con un efecto reconocible mínimo.
Responsabilidad	Es el cumplimiento de las obligaciones o cuidado al hacero decidir algo, o bien, una forma de responder que implicael claro conocimiento de que los resultados de cumplir, ono, las obligaciones, recae sobre uno mismo.
Responsable de seguridad	Persona o personas a las que el responsable del fichero ha asignado formalmente la función de coordinar y controlar las medidas de seguridad aplicables.
Responsabledel fichero	Persona física o jurídica, de naturaleza pública o privada u órgano administrativo, que decida sobre la finalidad, contenido y uso del tratamiento.
Respuesta	Contestación con palabras, texto o acción a algo oalguien que lo requiere.
RFC6979	En inglés, “Request For Comment” para el uso deterministadel algoritmo de firma digital DSA, y el algoritmo de firma de digital de curva elíptica.
Riesgo	Combinación de la probabilidad de ocurrencia de unevento y sus consecuencias.
	El potencial de que una amenaza específica explote las debilidades de un activo o grupo de activos para ocasionar pérdida y/o daño a los activos. Por lo general se mide por medio de una combinación del impacto y la probabilidad de ocurrencia.
	Posibilidad de que se produzca un impacto determinadoen un activo, en un dominio o en toda la organización.
Riesgo acumulado	Dícese del riesgo calculado resultado de tomar en consideración el valor propio de un activo y el valor de los activos que depende de él. Este valor se combina con ladegradación causada por una amenaza y la frecuencia estimada de la misma.
Riesgo de Responsabilidad Civil	Posibilidad de ser reclamado por los daños causados a terceros, por culpa o negligencia del autor del daño, o sin necesidad de culpa cuando se realiza una actividad de riesgo, para reparar o indemnizar dicho daño.

TÉRMINO	DEFINICIÓN
Riesgo informático (riesgo cibernético)	Aquel que puede producir un daño en los sistemas de información de una organización. El riesgo puede tener su origen en cualquier componente del sistema: equipos, aplicaciones, comunicaciones... Se puede producir como consecuencia de ataques de piratas informáticos o hackers y por fallos o errores no intencionados. Los daños pueden ser la alteración, modificación, destrucción o pérdida de información, el acceso indebido a la información y la falta de disponibilidad de servicio.
Riesgo laboral	Posibilidad de que un trabajador sufra un determinado daño derivado del trabajo. Para calificar un riesgo desdeel punto de vista de su gravedad, se valorarán conjuntamente la probabilidad de que se produzca el daño y la severidad del mismo.
Riesgo laboral grave e inminente	Aquel que resulte probable que se materialice en un futuroinmediato y pueda suponer un daño grave para la saludde los trabajadores.
Riesgo Patrimonial	Aquel que implica una disminución o pérdida, total o parciadel patrimonio del asegurado como consecuencia de un evento que puede afectarle.
Riesgo residual	Riesgo remanente que existe después de que se hantomado las medidas de seguridad.
	Riesgo que se da tras la aplicación de salvaguardas dispuestas en un escenario de simulación o en el mundoreal.
Riesgos Financieros	Aquellos que se relacionan con la capacidad económicadel asegurado, en relación con el capital asegurado.
Riesgos Legales	Incertidumbre relacionada con los riesgos legales, regulatorio y contractuales que inciden sobre los objetivos de l Organización y que pueden surgir en su entorno jurídico plos actos u omisiones de la misma, de sus accionistas y de otroterceros. Riesgo de recibir sanciones como consecuencia dincumplimiento o infracción de la normativa legal requerimientos de órganos reguladores y/o supervisores, consecuencia del desconocimiento, la inobservancia dolos o culposa de la misma. Riesgos por incumplimient contractual, extracontractual, estructural y litigioso.

TÉRMINO	DEFINICIÓN
Risk Assessment	Proceso total de la identificación, del análisis y de laevaluación del riesgo.
Rol	Función que una persona desempeña en un lugar o unasituación.
Router (rúter, encaminador, enrutador)	Es un dispositivo que distribuye tráfico de red entre dos o más diferentes redes. Un router está conectado al menos a dos redes, generalmente LAN o WAN y el tráfico que recibeprocedente de una red lo redirige hacia la(s) otra(s) red(es). En términos domésticos un router es el dispositivo que proporciona el proveedor de servicios de telefonía (o ISP) y que permite conectar nuestra LAN doméstica con la red del IS. El router comprueba las direcciones de destino de los paquetes de información y decide por qué ruta serán enviados, para determinar el mejor camino emplean cabeceras y tablas de comparación.
RLOPD	Real Decreto 1720/2007 de 21 de Diciembre, por el que seaprueba el Reglamento de desarrollo de la Ley Orgánica15/1999, de 13 de diciembre, de protección de datos decarácter personal.
Salvaguarda	Procedimiento o mecanismo tecnológico que reduce elriesgo.
Sarbanes Oxley (SOX)	Ley cuyo objetivo es garantizar la creación de mecanismosde auditoría y seguridad confiables en las empresas, incluyendo reglas para la creación de comités encargados de supervisar sus actividades y operaciones,de modo que se mitiguen los riesgos al negocio, se evite la ocurrencia de fraudes y se asegure que haya medios de identificarlos cuando ocurren, asegurando la transparencia en la gestión de las empresas.
SDLC	Ciclo de vida del desarrollo de sistemas. Las fases utilizadas en el desarrollo o adquisición de un sistema de software.Las fases típicas incluyen al estudio de factibilidad, el estudio de los requerimientos, la definición de requerimientos, el diseño detallado, la programación, laspruebas, la instalación y la revisión post-implantación.

TÉRMINO	DEFINICIÓN
Seguridad	La capacidad de las redes o de los sistemas de información de resistir, con un determinado nivel de confianza, los accidentes o acciones ilícitas o malintencionadas que comprometan la disponibilidad, autenticidad, integridad y confidencialidad de los datos almacenados o transmitidos, así como de los servicios que dichas redes y sistemas ofrecen o hacen accesibles
Seguridad de la información	La preservación de la confidencialidad, integridad y disponibilidad de la información. Pueden estar involucradas, además, otras propiedades tales comoautenticidad, responsabilidad, no repudio y fiabilidad.
Segregación de Funciones	Control que previene que una persona ejecute todas lastareas de un proceso crítico para el negocio, evitando laposibilidad de fraude o un uso indebido de un privilegio,p.ej.: una persona que realiza una solicitud no puede ser lamisma que la apruebe.
Segregación/ Separación detareas	Un control interno básico que previene y detecta errores o irregularidades por medio de la asignación a individuos diferentes, de la responsabilidad de iniciar y registrar las transacciones y la custodia de los activos.
Servicio	Conjunto de acciones que tienen como resultado llevar acabo al menos una actividad en la interfaz entre el proveedor y el cliente.
Servicio de lasociedad de la información	Todo servicio prestado normalmente a título oneroso, a distancia, por vía electrónica y a petición individual del destinatario.
Servicio de prevención	Conjunto de medios humanos y materiales necesarios pararealizar las actividades preventivas a fin de garantizar laadecuada protección de la seguridad y la salud de los trabajadores, asesorando y asistiendo para ello al empresario, a los trabajadores y a sus representantes y a los órganos de representación especializados.

TÉRMINO	DEFINICIÓN
Servidor	Puede entenderse como servidor tanto el software que realiza ciertas tareas en nombre de los usuarios, como elordenador físico en el cual funciona ese software, una máquina cuyo propósito es proveer y gestionar datos dealgún tipo de forma que estén disponibles para otras máquinas que se conecten a él. Así, se entiende por servidor tanto el equipo que almacena una determinada información como el programa de software encargado de gestionar dicha información y ofrecerla. Algunos ejemplos de servidores son los que proporcionan el alojamiento de sitios web y los que proporcionan el servicio de envío, reenvío y recepción de correos electrónicos.
Severidad	Rigor y exactitud al juzgar.
SGSI	Un Sistema de Gestión de la seguridad de la Información (SGSI) es un conjunto de políticas de seguridad de la información que siguen la norma ISO/IEC 27001. Un SGSI es para una organización el diseño, implantación, mantenimiento de un conjunto de procesos para gestionar eficientemente la accesibilidad de la información,buscando asegurar la confidencialidad, integridad y disponibilidad de los activos de información minimizando a la vez los riesgos de seguridad de la información.
Single sign on	Concepto que consiste en la autenticación única por parte del usuario para acceder a sus recursos. La idea esintroducir una única vez el nombre de usuario y contraseña, sin necesidad de volver a facilitarlo a la horade acceder a nuevos recursos en los que aún no se habíaautenticado.
Sistemas de detección de intrusos(IDS)	Un IDS inspecciona la actividad en la seguridad del host yla red para identificar patrones sospechosos que pudieran ser indicadores de un ataque al sistema o la red.
Sistema de Gestión de Seguridad de la Información SGSI	Aquella parte del sistema global de gestión, basada en una aproximación del riesgo de negocio, para establecer,implantar, poner en marcha, controlar, revisar, mantener ymejorar la seguridad de la información.

TÉRMINO	DEFINICIÓN
Sistema de Gestión de continuidad del negocio	Parte del Sistema de Gestión global que establece, implanta, opera, supervisa, revisa, mantiene y mejora lacontinuidad del negocio.
Sistemas de información	Conjunto de elementos físicos, lógicos, elementos de comunicación, datos y personal que permiten el almacenamiento, transmisión y proceso de la información.
Sistemas de Reputación	En los servicios de compraventa online se suelen adoptarsistemas de reputación. Estos sistemas permiten conocer la opinión de otros compradores y sus experiencias para valorar si el sitio merece nuestra confianza. Estos sistemas permiten que los usuarios que han utilizado un servicio de compraventa online publiquen sus opiniones yexperiencias con éste y califiquen el servicio. A partir deesta información, nosotros podemos hacernos una idea del nivel de confianza, seguridad y garantía que podemos obtener del servicio si decidimos utilizarlo. Estos sistemas son ventajosos tanto para los propietarios delos servicios de compraventa online como para sus usuarios, por esto, no es de extrañar que las páginas especializadas en compraventa, subastas y venta por Internet demuestren su interés en utilizarlos. Otro ejemplo de sistema de reputación son las listas negrasque valoran si una dirección IP son emisoras de spam oque valoran si una dirección IP aloja phishing. Estos sistemas de reputación ayudan a evitar ser víctimas despam o phishing.
Sistemas operativos	Windows, Linux, Unix, OS390 entre otros.
Site-to-site VPN	Esquema VPN que se utiliza para conectar oficinas remotascon la sede central de la organización.
Skype	Skype es un software propietario que permite comunicaciones de texto, voz y vídeo sobre internet (VoIP).
SLA	Acuerdo de nivel de servicio. Acuerdo por escrito entre un proveedor de servicios y los usuarios del cliente, el cualdocumenta los niveles de servicio acordados para un servicio prestado.
Smartphone	Tipo de teléfono móvil con una mayor capacidad de almacenar datos y realizar actividades semejantes a las deuna microcomputadora y con una mayor conectividad que un teléfono convencional.

TÉRMINO	DEFINICIÓN
Sniffer	Un sniffer es un programa que monitoriza la información quecircula por la red con el objeto de capturar información. Las tarjetas de red pueden verificar si la información recibida está dirigida o no a su sistema. Si no es así, la rechaza. Un sniffer lo que hace es colocar a la placa de red en un modo el cual desactiva el filtro de verificación de direcciones (promiscuo) y por lo tanto acepta todos los paquetes que llegan a la tarjeta de red del ordenador donde está instalado estén dirigidos o no aese dispositivo. El tráfico que no viaje cifrado podrá por tanto ser «escuchado» por el usuario del sniffer. El análisis de tráfico puede ser utilizado también para determinar relaciones entre varios usuarios (conocer conqué usuarios o sistemas se relaciona alguien en concreto). No es fácil detectar si nuestro tráfico de red está siendo «escuchado» mediante un sniffer, por lo que siempre es recomendable utilizar tráfico cifrado en todas las comunicaciones.
Software	Conjunto de programas, instrucciones y reglas informáticas para ejecutar ciertas tareas en una computadora.
Software antivirus	Un software de aplicación utilizado en múltiples puntos en una arquitectura de TI diseñado para detectar y posiblemente eliminar códigos de virus antes de que ocasionen algún daño, así como reparar o poner en cuarentena los archivos que ya han sido infectados.
Software base	Base de datos, servidores Web, servidores de aplicaciones,servidores de correo electrónico, aplicaciones comerciales (como SAP y otras) y cualquier tipo de software comercial.
Software Homologado	Aplicación expresamente aprobada por los responsablespara su uso dentro de SPIKA.
Soporte	Objeto físico susceptible de ser tratado en un sistema deinformación y sobre el cual se pueden grabar o recuperar datos.

TÉRMINO	DEFINICIÓN
Spam	Mensajes no solicitados, habitualmente de tipo publicitario, enviados en cantidades masivas que perjudican de una u otra manera al receptor. Aunque sepuede hacer por distintas vías, la más utilizada entre elpúblico en general es la basada en el correo electrónico
Spoofing	Es una técnica de suplantación de identidad en la Red, llevada a cabo por un ciberdelincuente generalmente gracias a un proceso de investigación o con el uso de malware. Los ataques de seguridad en las redes usando técnicas de spoofing ponen en riesgo la privacidad de losusuarios, así como la integridad de sus datos. De acuerdo a la tecnología utilizada se pueden diferenciarvarios tipos de spoofing: IP spoofing: consiste en la suplantación de la dirección IPde origen de un paquete TCP/ IP por otra dirección IP a lacual se desea suplantar. ARP spoofing: es la suplantación de identidad por falsificación de tabla ARP. ARP (Address Resolution Protocol) es un protocolo de nivel de red que relaciona unadirección MAC con la dirección IP del ordenador. Por lo tanto, al falsear la tabla ARP de la víctima, todo lo que seenvíe a un usuario, será direccionado al atacante. DNS spoofing: es una suplantación de identidad por nombrede dominio, la cual consiste en una relación falsa entre IP y nombre de dominio. Web spoofing: con esta técnica el atacante crea una falsapágina web, muy similar a la que suele utilizar el afectadocon el objetivo de obtener información de dicha víctima como contraseñas, información personal, datos facilitados, páginas que visita con frecuencia, perfil del usuario, etc. Losataques de phishing son un tipo de Web spoofing. Mail spoofing: suplantación de correo electrónico bien sea de personas o de entidades con el objetivo de llevara cabo envío masivo de spam.
Spyware	Software que recopila información de un ordenador y después transmite esta información a una entidad externasin el conocimiento o el consentimiento del propietario delordenador.
SQL Injection	(ver inyección SQL)

TÉRMINO	DEFINICIÓN
SSL	Secure Sockets Layer: Protocolo criptográfico que proporciona comunicaciones seguras en Internet. Proporciona autenticación y privacidad de la información entre extremos de comunicación sobre Internet mediante el uso de criptografía
Subcontratada	Empresa prestadora de servicios que tiene el conocimiento técnico y/o la tecnología especializada para la realización de determinada actividad.
Subcontratado	Todo empleado de una empresa subcontratada que desarrolla actividades de prestación de servicio para SPIKA, siendo la ejecución de tu trabajo vinculada a un contrato comercial entre las empresas.
Suceso	Ocurrencia o cambio de un conjunto particular de circunstancias.
Suplantación de Identidad	Es la actividad maliciosa en la que un atacante se hace pasar por otra persona para cometer algún tipo de fraude,acoso (cyberbulling). Un ejemplo es, en las redes sociales, crear un perfil de otrapersona e interactuar con otros usuarios haciéndose pasar por ella.
Tablero de control	Una herramienta para establecer las expectativas de una organización en cada nivel y para comparar de forma continua el desempeño contra las metas establecidas.
Tablero de control de inversión en TI	Graficar costos y retornos sobre la inversión de los proyectos de inversión en ti en términos de valor de negocio para la empresa.
Tablet	Denominada también tableta. Es un dispositivo electrónico portátil con pantalla táctil y con múltiples prestaciones de tamaño superior a un teléfono móvil.
TCO	Costo total de la propiedad.

TÉRMINO	DEFINICIÓN
TCP/IP	Familia de protocolos sobre los cuales funciona Internet, permitiendo la comunicación entre todos los servidores conectados a dicha red. TCP/IP consta entre otros muchos, del protocolo IP (Internet Protocol), que se ocupa de transferir los paquetes de datos hasta su destino correcto y el protocolo TCP (Transfer Control Protocol), que se ocupa de garantizar que la transferencia se lleve a cabo de forma correcta y confiable. Entre otros muchos, esta familia consta de los protocolosICMP, UDP, DNS, HTTP y FTP.
Tercera parte	Aquella persona o entidad que está reconocida como independiente de las partes implicadas para el asunto encuestión.
Test de Penetración	(ver Pentest)
Texto Claro (texto plano, plain text)	Es el mensaje que se cifra.
TI	Tecnología de información.
Ticket	Es un número que actúa como justificante de la operación realizada.
Tiempo MáximoAceptable de Interrupción	Tiempo necesario para que los impactos desfavorables que pudiesen surgir como consecuencia de no suministrar un producto/servicios o de no realiza una actividad, se transformen en inaceptables.
Tipo	Modelo que reúne las características esenciales de un conjunto y que sirve como pauta para imitarlo, reproducirlo o copiarlo.
Token	Generador dinámico de contraseñas.
Transferencia de datos	El transporte de los datos entre sistemas informáticos por cualquier medio de transmisión, así como el transporte desoportes de datos por correo o por cualquier otro medioconvencional.

TÉRMINO	DEFINICIÓN
Transferencia Internacional de datos	Tratamiento de datos que supone una transmisión de losmismos fuera del territorio del espacio económico europeo, bien constituya una cesión o comunicación dedatos, bien tenga por objeto la realización de un tratamiento de datos por cuenta del responsable del fichero establecido en territorio español.
Tratamiento De Datos	Operaciones y procedimiento técnicos, de carácter automatizado que permitan la recogida, grabación, conservación, elaboración, modificación, bloqueo y cancelación, así como las cesiones de datos que resulten de comunicaciones, consultas, interconexiones y transferencias.
Tratamiento del riesgo	Proceso de selección y de implantación de medidas paramodificar el riesgo.
Trazabilidad	Aseguramiento de que en todo momento se podrádeterminar quién hizo qué y en qué momento.
Troyano	Programa informático que lleva en su interior la lógica necesaria para que el creador del programa puedaacceder al interior del sistema en el que se introduce demanera subrepticia (de ahí su nombre).
Twitter	Twitter es una aplicación web gratuita de microbloggingque reúne las ventajas de los blogs, las redes sociales y lamensajería instantánea.
Usuario	Una persona que utiliza los sistemas empresariales.
	Sujeto o proceso autorizado para acceder a datos orecursos.
Valor	De un activo. Es una estimación del coste inducido por la materialización de una amenaza.
Valor acumulado	Considera tanto el valor propio de un activo como el valorde los activos que dependen de él.
Valoración del riesgo	Proceso global de análisis y evaluación del riesgo.
Virtualización	La virtualización es un medio para crear una versión virtual de un dispositivo o recurso, como un servidor, o una red, en una máquina física, generalmente con el apoyo de unsoftware que implementa una capa de abstracción paraque la maquina física y la virtual puedan comunicarse ycompartir recursos.

TÉRMINO	DEFINICIÓN
Virus informático	Es un programa o software que se auto ejecuta y se propaga insertando copias de sí mismo en otro programao documento.
VLAN	(Virtual LAN) Es una red de computadoras lógicamente independiente. Varias VLANs pueden coexistir en un único switch físico. Se comportan como si estuviesen conectados al mismo cable, aunque pueden estar en realidad conectados físicamente a diferentes segmentosde una red de área local.
VPN (Red privada virtual)	Una red privada segura que utiliza la infraestructura de las telecomunicaciones públicas para transmitir datos. En comparación con un sistema mucho más costoso de líneas propias o rentadas que solo pueden ser utilizadaspor una compañía, las VPN son utilizadas por empresas tanto para extranets como para áreas amplias de Intranets. Mediante el uso de encriptación y autenticación, una VPN encripta todos los datos que pasan entre dos puntos de Internet, manteniendo la privacidad y la seguridad.
Vulnerabilidad	Debilidad de un activo o grupo de activos que puede serexplotada por una o más amenazas.
	Vulnerabilidad de un activo es la potencialidad o posibilidad de ocurrencia de la materialización de una amenaza sobre dicho activo.
Vulnerabilidad de Seguridad	Fallos o deficiencias de un programa que pueden permitir que un usuario no legítimo acceda a la información o llevea cabo operaciones no permitidas de manera remota. Los agujeros de seguridad pueden ser aprovechadas poratacantes mediante exploits, para acceder a los sistemascon fines maliciosos. Las empresas deben ser conscientes de estos riesgos y mantener una actitud preventiva, así como llevar un control de sus sistemas mediante actualizaciones periódicas.
Warm site	Es similar a un hot site; sin embargo, no está completamente equipado con todo el hardware necesario para la recuperación.
Web	Página electrónica adaptada para WWW.

TÉRMINO	DEFINICIÓN
Whistleblowers	Es una persona que expone cualquier tipo de información o actividad que es considerada ilegal, no ética, o no correcta en una organización ya sea privada o pública.
WIFI	(Wireless Fidelity) Es un conjunto de estándares para redesinalámbricas basados en las especificaciones 802.11. Creado para ser utilizado en redes locales inalámbricas; esfrecuente que en la actualidad también se utilice para acceder a Internet.
WordPress	WordPress es un sistema de gestión de contenido, o CMS por sus siglas en inglés (Content Management System)enfocado, principalmente, a la creación de blogs. Ha sidodesarrollado por Automattic bajo licencia GPL, y sobre PHP para entornos que ejecuten MySQL y Apache.
Zombie	Es el nombre que se da a los ordenadores controlados demanera remota por un ciberdelincuente al haber sido infectados por un malware. El atacante remoto generalmente utiliza el ordenador zombie para realizar actividades ilícitas a través de la Red, como el envío de comunicaciones electrónicas no deseadas, o la propagación de otro malware. Son sistemas zombie los ordenadores que forman parte deuna botnet, a los que el bot master utiliza para realizar acciones coordinadas como ataques de denegación de servicio.

5 REFERENCIAS

- Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo de 27 de abril de 2016.
- Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (LOPDGDD).
- ISO / IEC 27001:2022.
- ISO / IEC 22301:2020.
- Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información (MAGERIT).
- Certified Information Security Manager (ISACA/CISM).
- Sector de normalización del Órgano permanente de la Unión Internacional de Telecomunicaciones (UIT-T).
- Real Decreto Legislativo 1/1996, de 12 de abril, por el que se aprueba el texto refundido de la Ley de Propiedad Intelectual, regularizando, aclarando y armonizando las disposiciones legales vigentes sobre la materia (LPI).
- Ley 31/1995, de 8 de noviembre, de prevención de Riesgos Laborales (LPRL).
- Ley 34/2002, de 11 de julio, de servicios de la sociedad de la información y de comercio electrónico (LSSICE).